CPE 334 Introduction to Software Engineering in the Age of AI Agents

Semester 1/2026

Lab 3 Report

TokTickIT Users, Roles, IT Staff Ticketing, and Admin Screens

ผู้จัดทำ	Anapat Banjerdsilp
รหัสนักศึกษา	67070501049
Section	1
GitHub	@PpAnpt
Repository	https://github.com/PpAnpt/toktickit
Issues / Kanban	https://github.com/PpAnpt/Lab1-TokTickIT/issues https://github.com/users/PpAnpt/projects/3
Branches	feature/* ⟶ `lab3-staging` ⟶ `main`
Peer reviewer	ศิวรักษ์ ฉัตรวิชัย (Siwarak Chatvichai) — @BBINGOAL — 67070501086

สารบัญ

Part	หัวข้อ	คะแนน
1	Git Use with Engineering Workflow	10
2	Spec DD	5
3	Test DD and Traceability	10
4	AI Use with Reflection	5
5	Working Login and Password Change UI	5
6	Working IT Staff Ticket Queue UI	5
7	Working IT Staff Ticket Detail UI	10
8	Working Administrator User Management UI	5
9	Zen Green UI and Responsive Evidence	5

Repository และ branch `main` เป็นแหล่งข้อมูลหลัก (source of truth) ลิงก์ในรายงานชี้ไปที่ GitHub ทั้งหมด

Answer Part 1: Git Use with Engineering Workflow

1.1 Branch Flow และ Commit History

งาน Lab 3 แบ่งเป็น feature branch ตาม Issue แต่ละ branch เปิด Pull Request เข้า `lab3-staging` ผ่านการ review และ approve โดย @BBINGOAL ก่อน merge จากนั้นจึงรวม `lab3-staging` เข้า `main`

```
main
 └── lab3-staging
      ├── feature/1-specs-contract               PR #18  (Issue #11)  Merged 2026-09-13
      ├── feature/lab3-2-auth-foundation         PR #19  (Issue #12)  Merged 2026-09-18
      ├── feature/lab3-3-staff-queue             PR #20  (Issue #13)  Merged 2026-09-19
      ├── feature/lab3-4-staff-operation         PR #21  (Issue #14)  Merged 2026-09-19
      ├── feature/lab3-5-admin-user-management   PR #22  (Issue #15)  Merged 2026-09-19
      ├── feature/lab3-6-e2e-regression-release  PR #23  (Issue #16)  Merged 2026-09-19
      ├── feature/lab3-7-security-hardening      PR #24  (Issue #17)  Merged 2026-10-04
      ├── feature/lab3-8-release-docs            PR #25  (Issue #18)  Merged 2026-10-04
      └── feature/lab3-9-release-prep            PR #26  (Issue #18)  Merged 2026-10-04
 lab3-staging → main                             PR #27  (Issue #18)  Merged 2026-10-04
      └── feature/lab3-10-submission-evidence    PR #28  (Issue #19)
 lab3-staging → main                             PR #29  (Issue #19)
```

Git graph ของ `lab3-staging` (feature branches ที่ merge ผ่าน Pull Request)

```
*   18eb063 Merge pull request #28 from PpAnpt/feature/lab3-10-submission-evidence
|\
| * 2e97c26 docs(lab-03): sync submission evidence and final review records to main
| *   13e94da Merge pull request #27 from PpAnpt/lab3-staging
| |\
| |/
|/|
* |   9ce873b Merge pull request #26 from PpAnpt/feature/lab3-9-release-prep
|\ \
| * | c49e148 docs(lab-03): record PR #25 review and add submission report builder
|/ /
* |   655c3f0 Merge pull request #25 from PpAnpt/feature/lab3-8-release-docs
|\ \
| * | dcbf84e docs(lab-03): fill in release docs PR number (#25)
| * | 5c6a0b9 docs(lab-03): list the real Lab 3 issues and Kanban board in Part 1
| * | cbb77f8 docs(lab-03): record PR #24 review and release test results
|/ /
* |   ae201be Merge pull request #24 from PpAnpt/feature/lab3-7-security-hardening
|\ \
| * | 7fdc9cb docs(lab-03): update submission report, reviewer log, and UI spec for hardening work
| * | 542cf4c docs(lab-03): specification v1.1, API/UI specs, traceability, and README
| * | 6be2b0e test(e2e): rewrite requester regression, harden flows, add screenshot capture
| * | f324e09 feat(client): authenticated requester flow, public comments, and responsive fixes
| * | 215969d fix(server): enforce authenticated identity, real logout, and Lab 3 migration
|/ /
* | c0f6fff fix(client): remove legacy dev requester selector from login page
* |   7f49cf4 Merge pull request #23 from PpAnpt/feature/lab3-6-e2e-regression-release
|\ \
| * | 6af3169 docs(lab-03): add peer review template and pull request tracking matrix
| * | 32e1073 docs(lab-03): add AI reflection documentation and update README with Lab 3 milestone
| * | 9098474 fix(e2e): enhance backwards compatibility and dynamic ticket summaries
| * | a839c25 chore: add playwright test results to gitignore
| * | 66b1da8 feat: add e2e test suites for authentication and user administration flows
| * | be48775 test: add E2E test and test results for lab-03 staff ticket flow
| * | 9f3f080 test: add last-run.json test results
| * | b6e9c11 test: add E2E tests for authentication and password change flow
| * | e844aa0 test: add Playwright configuration and end-to-end test suites for authentication, staff workflows, and user adminis
tration
|/ /
* |   b4d20f9 Merge pull request #22 from PpAnpt/feature/lab3-5-admin-user-management
|\ \
| * | edc1c5d feat(client): implement Administrator user management UI, navigation, and tests
| * | 8087a64 feat: initialize express server entry point and user-admin api test suite
| * | b019f26 feat: implement Express application setup and admin user management routes
|/ /
* |   5b23c4c Merge pull request #21 from PpAnpt/feature/lab3-4-staff-operation
```

```
|\ \
| * | 77140e8 fix(client): add optional metadata fields to StaffTicket type interface
```

Git graph หลัง merge `lab3-staging` เข้า `main`

```
Terminal — git graph on main
PS C:\Users\Anapat\Downloads\Lab1_Starter_Scaffold\toktickit> git branch --show-current; git log -1 --format="%h %s"
main
13e94da Merge pull request #27 from PpAnpt/lab3-staging
PS C:\Users\Anapat\Downloads\Lab1_Starter_Scaffold\toktickit> git log --graph --oneline --decorate=short -34 main
*   13e94da (HEAD -> main, origin/main, origin/HEAD) Merge pull request #27 from PpAnpt/lab3-staging
|\
| *   9ce873b (origin/lab3-staging) Merge pull request #26 from PpAnpt/feature/lab3-9-release-prep
| |\
| | * c49e148 (origin/feature/lab3-9-release-prep, feature/lab3-9-release-prep) docs(lab-03): record PR #25 review and add submission report builder
| |/
| *   655c3f0 (lab3-staging) Merge pull request #25 from PpAnpt/feature/lab3-8-release-docs
| |\
| | * dcbf84e (origin/feature/lab3-8-release-docs, feature/lab3-8-release-docs) docs(lab-03): fill in release docs PR number (#25)
| | * 5c6a0b9 docs(lab-03): list the real Lab 3 issues and Kanban board in Part 1
| | * cbb77f8 docs(lab-03): record PR #24 review and release test results
| |/
| *   ae201be Merge pull request #24 from PpAnpt/feature/lab3-7-security-hardening
| |\
| | * 7fdc9cb (origin/feature/lab3-7-security-hardening, feature/lab3-7-security-hardening) docs(lab-03): update submission report, reviewer log, and UI spec for
hardening work
| | * 542cf4c docs(lab-03): specification v1.1, API/UI specs, traceability, and README
| | * 6be2b0e test(e2e): rewrite requester regression, harden flows, add screenshot capture
| | * f324e09 feat(client): authenticated requester flow, public comments, and responsive fixes
| | * 215969d fix(server): enforce authenticated identity, real logout, and Lab 3 migration
| |/
| * c0f6fff fix(client): remove legacy dev requester selector from login page
| *   7f49cf4 Merge pull request #23 from PpAnpt/feature/lab3-6-e2e-regression-release
| |\
| | * 6af3169 (origin/feature/lab3-6-e2e-regression-release, feature/lab3-6-e2e-regression-release) docs(lab-03): add peer review template and pull request tracking
matrix
| | * 32e1073 docs(lab-03): add AI reflection documentation and update README with Lab 3 milestone
| | * 9098474 fix(e2e): enhance backwards compatibility and dynamic ticket summaries
| | * a839c25 chore: add playwright test results to gitignore
| | * 66b1da8 feat: add e2e test suites for authentication and user administration flows
| | * be48775 test: add E2E test and test results for lab-03 staff ticket flow
| | * 9f3f080 test: add last-run.json test results
| | * b6e9c11 test: add E2E tests for authentication and password change flow
| | * e844aa0 test: add Playwright configuration and end-to-end test suites for authentication, staff workflows, and user administration
| |/
| *   b4d20f9 Merge pull request #22 from PpAnpt/feature/lab3-5-admin-user-management
| |\
| | * edc1c5d (origin/feature/lab3-5-admin-user-management, feature/lab3-5-admin-user-management) feat(client): implement Administrator user management UI,
navigation, and tests
| | * 8087a64 feat: initialize express server entry point and user-admin api test suite
| | * b019f26 feat: implement Express application setup and admin user management routes
| |/
| *   5b23c4c Merge pull request #21 from PpAnpt/feature/lab3-4-staff-operation
| |\
| | * 77140e8 (origin/feature/lab3-4-staff-operation, feature/lab3-4-staff-operation) fix(client): add optional metadata fields to StaffTicket type interface
| | * fcbbeff feat: add StaffTicketDetail component and corresponding test suite
| | * 1c9ce89 feat: add main application component and StaffTicketDetail test suite
| | * 93280a8 feat: add client-side API services and StaffTicketDetail component
| | * 9c4da23 feat(server): implement staff ticket operations, status workflow, and comments/notes APIs
```

Git graph หลัง merge lab3-staging เข้า main

1.2 GitHub Project (Kanban) และ Issues

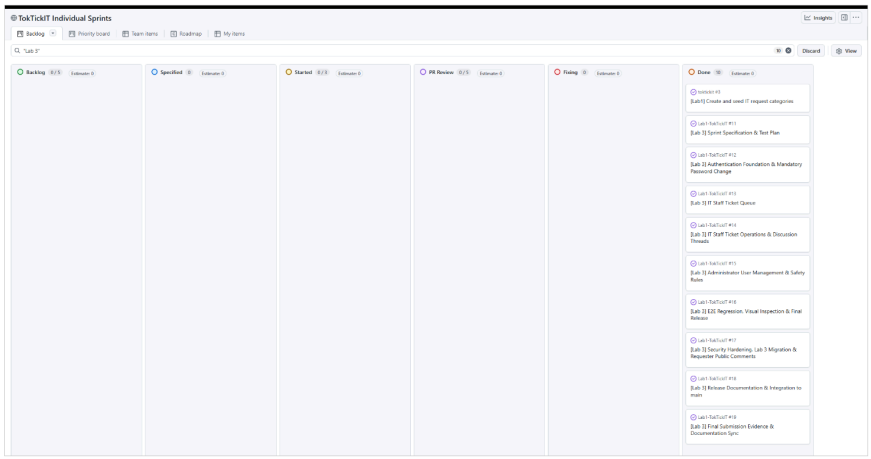
Kanban board: TokTickIT Individual Sprints — สถานะ Backlog ⟶ Specified ⟶ Started ⟶ PR Review ⟶ Fixing ⟶ Done

Issue ของ Lab 3 อยู่ใน repository PpAnpt/Lab1-TokTickIT แต่ละ Issue มีเกณฑ์ `AC 1, AC 2, …` และเชื่อมกับ Pull Request ใน `PpAnpt/toktickit`

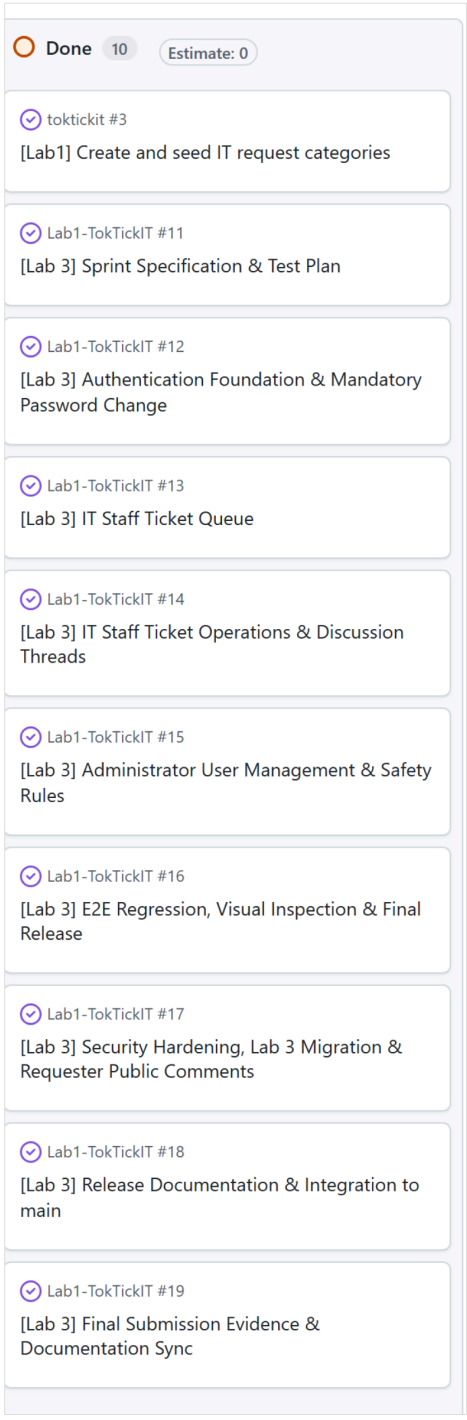
Issue	งาน	Pull Request	สถานะบน Kanban
#11	[Lab 3] Sprint Specification & Test Plan	#18	Done
#12	[Lab 3] Authentication Foundation & Mandatory Password Change	#19	Done
#13	[Lab 3] IT Staff Ticket Queue	#20	Done
#14	[Lab 3] IT Staff Ticket Operations & Discussion Threads	#21	Done

#15	[Lab 3] Administrator User Management & Safety Rules	#22	Done
#16	[Lab 3] E2E Regression, Visual Inspection & Final Release	#23	Done
#17	[Lab 3] Security Hardening, Lab 3 Migration & Requester Public Comments	#24	Done
#18	[Lab 3] Release Documentation & Integration to main	#27	Done
#19	[Lab 3] Final Submission Evidence & Documentation Sync	#29	Done

ภาพรวม Kanban board (กรอง "Lab 3") — ทุกคอลัมน์ว่าง ยกเว้น Done



คอลัมน์ Done (ขยาย) — Issue #11–#19



GitHub Project (Kanban) board ที่ Issue ของ Lab 3 ทั้งหมดอยู่ในคอลัมน์ Done

1.3 Peer Review (reviewer.md)

PR	Branch ⟶ base	สร้าง	Merge	ความเห็น Reviewer (@BBINGOAL)
#18	`feature/1-specs-contract`	2026-09-13	2026-09-13	ครบถ้วนครับ เรียบร้อยครับ **(Approved)**
#19	`feature/lab3-2-auth-foundation`	2026-09-18	2026-09-18	โอ้โห้ ครบถ้วนทุกส่วนเลยครับ เรียบร้อยมากครับ **(Approved)**
#20	`feature/lab3-3-staff-queue`	2026-09-19	2026-09-19	ตรวจสอบโค้ด Staff Queue API, UI และ Unit Tests แล้ว ผ่านครบถ้วนตาม spec ครับ **(Approved)**
#21	`feature/lab3-4-staff-operation`	2026-09-19	2026-09-19	Status transition matrix และ RBAC comments/notes ทำงานถูกต้องตาม spec ครับ **(Approved)**
#22	`feature/lab3-5-admin-user-management`	2026-09-19	2026-09-19	ถูกต้องครบถ้วน เทสผ่านหมดครับ **(Approved)**
#23	`feature/lab3-6-e2e-regression-release`	2026-09-19	2026-09-19	ครบถ้วนเรียบร้อยดีครับ **(Approved)**
#24	`feature/lab3-7-security-hardening`	2026-10-04	2026-10-04	เรียบร้อยครับ **(Approved)**
#25	`feature/lab3-8-release-docs`	2026-10-04	2026-10-04	เรียบร้อยดีครับ **(Approved)**
#26	`feature/lab3-9-release-prep`	2026-10-04	2026-10-04	Merged โดย @PpAnpt (ไม่มี review)
#27	`lab3-staging → main (release)`	2026-10-04	2026-10-04	Merged โดย @PpAnpt (ไม่มี review)
#28	`feature/lab3-10-submission-evidence`	2026-10-04	2026-10-04	Merged โดย @PpAnpt (ไม่มี review)
#29	`lab3-staging → main`	2026-10-04	2026-10-04	Merged โดย @PpAnpt (ไม่มี review)

Rendered from docs/lab-03/reviewer.md

Lab 3: Peer Review

1. Reviewer Identity

- **Name**: Siwarak Chatvichai
- **Student ID**: 67070501086
- **GitHub Username**: @BBINGOAL

2. Pull Request Links

- **PR 1 (#18)**: https://github.com/PpAnpt/toktickit/pull/18
- **PR 2 (#19)**: https://github.com/PpAnpt/toktickit/pull/19
- **PR 3 (#20)**: https://github.com/PpAnpt/toktickit/pull/20
- **PR 4 (#21)**: https://github.com/PpAnpt/toktickit/pull/21

- **PR 5 (#22)**: https://github.com/PpAnpt/toktickit/pull/22
- **PR 6 (#23)**: https://github.com/PpAnpt/toktickit/pull/23
- **PR 7 (#24)**: https://github.com/PpAnpt/toktickit/pull/24 — Lab 3 hardening (`feature/lab3-7-security-hardening`)
- **PR 8 (#25)**: https://github.com/PpAnpt/toktickit/pull/25 — Release documentation (`feature/lab3-8-release-docs`)
- **PR 9 (#26)**: https://github.com/PpAnpt/toktickit/pull/26 — Release preparation (`feature/lab3-9-release-prep`)
- **Release PR (#27)**: https://github.com/PpAnpt/toktickit/pull/27 — `lab3-staging` ⟶ `main`
- **PR 10 (#28)**: https://github.com/PpAnpt/toktickit/pull/28 — Submission evidence & documentation sync (`feature/lab3-10-submission-evidence`)
- **PR (#29)**: https://github.com/PpAnpt/toktickit/pull/29 — `lab3-staging` ⟶ `main` (submission evidence)

3. Comments and Responses

PR / Context	Reviewer Comment (@BBINGOAL)	Author Response (@PpAnpt)	Action Taken
PR #18 (`docs: add Lab 3 specifications, test plan, UI guidelines...`)	ครบถ้วนครับ เรียบร้อยครับ	ขอบคุณครับ จัดทำ Engineering Spec, API Contract, UI Spec, และ Test Plan ครบทั้ง 24 Acceptance Criteria ครับ	ตรวจสอบความถูกต้องและ Merge เข้าสู่ `lab3-staging`
PR #19 (`Feature/lab3 2 auth foundation`)	โอ้โห้ ครบถ้วนทุกส่วนเลยครับ เรียบร้อยมากครับ	ขอบคุณครับ ใช้ bcryptjs แฮชรหัสผ่าน, JWT สำหรับ Session และบังคับเปลี่ยนรหัสผ่านเมื่อ `mustChangePassword=true`	รันเทสผ่านและ Merge เข้าสู่ `lab3-staging`
PR #20 (`Feature/lab3 3 staff queue`)	ตรวจสอบโค้ด Staff Queue API, UI และ Unit Tests แล้ว ผ่านครบถ้วนตาม spec ครับ	ขอบคุณครับ รองรับ Search, Multi-Filter (Status, Priority, Owner), Pagination และป้องกันสิทธิ์ RBAC เรียบร้อยครับ	รันเทสผ่านและ Merge เข้าสู่ `lab3-staging`
PR #21 (`Feature/lab3 4 staff operation`)	Status transition matrix และ RBAC comments/notes ทำงานถูกต้องตาม spec ครับ	ขอบคุณครับ ควบคุม State Machine ห้ามข้ามขั้นตอน และแยกระหว่าง Public Comments กับ Internal Notes อย่างปลอดภัยครับ	รันเทสผ่านและ Merge เข้าสู่ `lab3-staging`

PR / Context	Reviewer Comment (@BBINGOAL)	Author Response (@PpAnpt)	Action Taken
PR #22 (`Feature/lab3 5 admin user management`)	ถูกต้องครบถ้วน เทสผ่านหมดครับ	ขอบคุณครับ มีระบบ Self-deactivation guard และ Sole Admin guard พร้อมระบบรีเซ็ตรหัสผ่าน เริ่มต้นเรียบร้อยครับ	รันเทสผ่านและ Merge เข้าสู่ `lab3-staging`
PR #23 (`Feature/lab3 6 e2e regression release`)	ครบถ้วนเรียบร้อยดีครับ	ขอบคุณครับ ครอบคลุมการรันเทส 110 ข้อ และ E2E 7 ข้อ รันผ่าน 100% Zero Regression ครับ	ตรวจสอบผลการรันเทสต์และ Merge เข้าสู่ `lab3-staging`
PR #24 (`Feature/lab3 7 security hardening`)	เรียบร้อยครับ (Approved)	ขอบคุณครับ	Approved และ Merge เข้าสู่ `lab3-staging` โดย @BBINGOAL (2026-10-04)
PR #25 (`Feature/lab3 8 release docs`)	เรียบร้อยดีครับ (Approved)	ขอบคุณครับ	Approved และ Merge เข้าสู่ `lab3-staging` โดย @BBINGOAL (2026-10-04)
PR #26 (`Feature/lab3 9 release prep`)	— (ไม่มีความเห็น)	—	Merge เข้าสู่ `lab3-staging` โดย @PpAnpt (2026-10-04) ไม่มี review
PR #27 (`Release: Lab 3 lab3-staging → main`)	— (ไม่มีความเห็น)	—	Merge เข้าสู่ `main` โดย @PpAnpt (2026-10-04, commit `13e94da`) ไม่มี review

4. Final Approval

- ☑ Approved by Reviewer (@BBINGOAL) — PR #18–#25 approved and merged into `lab3-staging`
- ☐ PR #26 (release preparation) และ PR #27 (`lab3-staging` ⟶ `main`) — merge โดยผู้จัดทำโดยไม่มี review

1.4 README และ .gitignore

README.md อธิบายฟีเจอร์ของ Lab 3, โครงสร้างโปรเจกต์, การติดตั้ง (`prisma migrate deploy` + seed), คำสั่งทดสอบ, บัญชีทดสอบสำหรับ local development และลิงก์เอกสาร Lab 3 ทั้งหมด ไฟล์ `.gitignore` ป้องกันไม่ให้ไฟล์ `.env` (เช่น `JWT_SECRET`), dependencies, ไฟล์แนบที่อัปโหลด และผลการทดสอบ ถูก commit ขึ้น repository

.gitignore

```
# Dependency directories
node_modules/

# Environment variables
.env
.env.local

# Build outputs
dist/
build/

# Uploaded ticket attachments (Lab 2)
uploads/*
server/uploads/*
!**/uploads/.gitkeep

# Logs & Test Coverage
*.log
coverage/
test-results/
playwright-report/

# IDE & OS files
.vscode/
.idea/
.DS_Store
Thumbs.db


# Generated submission PDF (npm run report); attach it to
the submission instead of committing
docs/lab-03/lab-03-report.pdf
```

หัวข้อใน README.md

```
# TokTickIT - IT Service Desk (Lab 3: Authentication, IT S
taff Operations & User Administration)
## Key Features
### Lab 3: Authentication, Staff Operations & Administrati
on
### Lab 2: Requester Ticketing Core
## Tech Stack
## Project Structure
## Getting Started
### Prerequisites
### 1. Database
### 2. Backend (`server/`)
### 3. Frontend (`client/`)
## Running Automated Tests
## Default Seed Accounts (local development only)
## Documentation
```

1.5 โครงสร้าง Repository (Lab Sheet §12)

```
client/src/tests/lab-03/
├── AppShell.test.tsx
├── ChangePassword.test.tsx
├── Login.test.tsx
├── PublicComments.test.tsx
├── StaffTicketDetail.test.tsx
├── StaffTicketQueue.test.tsx
└── UserManagement.test.tsx
docs/lab-03/
├── ai-use.md
├── api-spec.md
├── reviewer.md
├── specification.md
├── submission-report.md
├── tests.md
└── ui-spec.md
e2e/lab-03/
├── authentication.spec.ts
├── staff-ticket-flow.spec.ts
└── user-administration.spec.ts
server/prisma/migrations/20260814102133_init_category/
└── migration.sql
server/prisma/migrations/20260831064515_init_lab_models/
└── migration.sql
server/prisma/migrations/20260930120000_lab3_users_roles_workflow/
└── migration.sql
server/prisma/migrations/
└── migration_lock.toml
server/tests/lab-03/
├── auth.api.test.ts
├── authorization.api.test.ts
├── comments-notes.api.test.ts
├── staff-queue.api.test.ts
├── staff-ticket-detail.api.test.ts
└── users-admin.api.test.ts
artifacts/lab-03/screenshots/
├── authentication/  (14 ภาพ)
├── requester-ticket-detail/  (6 ภาพ)
├── staff-queue/  (9 ภาพ)
├── staff-ticket-detail/  (9 ภาพ)
└── user-management/  (13 ภาพ)
```

Answer Part 2: Spec DD

ลิงก์: docs/lab-03/specification.md — ประกอบด้วย Functional Requirements FR-01–FR-14, Business Rules BR-01–BR-29, Role Authorization Matrix, Ticket Status Transition Matrix, Data Changes และ Migration, API Contract, Acceptance Criteria AC-01–AC-30, Definition of Done และ Assumptions & Decisions

หลักฐานว่า Specification มีอยู่ก่อน Implementation

เหตุการณ์	หลักฐาน	วันที่
Commit specification, tests, ui-spec, api-spec	`477a2d5` docs: add Lab 3 specifications, test plan, UI guidelines...	2026-09-13 09:04
Specification PR approved และ merged	PR #18	2026-09-13
Commit implementation แรก (Prisma schema)	`d3c4be8` feat: add Prisma database schema and server dependencies	2026-09-18 10:12
Implementation PR แรกเปิด	PR #19	2026-09-18
Revision v1.1 หลังตรวจทานเทียบ Lab Sheet	PR #24 (มีบันทึกใน §12 Revision History)	2026-10-04

Rendered from docs/lab-03/specification.md

Lab 3 Sprint Engineering Specification

1. Sprint Goal

Deliver secure authentication, role-based authorization (Requester, IT Staff, Administrator), mandatory first-login password change, operational IT Staff ticket management (Queue, Detail, Ownership, IT Priority, Status Transitions, Public Comments, Internal Notes), and minimalist Administrator user management while maintaining full backward compatibility with Lab 2 Requester ticketing features.

2. Stakeholder Request Interpretation

The system must transition from the temporary Development Requester selector to a real authentication system with email and password credentials. Administrator users need a minimalist User Management screen to view accounts, search/filter, create accounts with one assigned role, edit basic information, toggle active status, and issue initial passwords that force a change upon first login. Requesters must continue using all Lab 2 ticket features with identity strictly resolved from the authenticated session. IT Staff require a shared Ticket Queue and Ticket Detail screen to claim or reassign tickets, adjust IT Priority, perform permitted status changes, communicate via Public Comments, and record private Internal Notes. All backend APIs must enforce role and ownership security independently of client UI controls, adhering strictly to the Zen Green design system.

3. Scope

Included

- Real authentication with email/password, session/token management, current-user endpoint, and logout.
- Mandatory password change on first login or after administrator password reset.
- Role-based authorization for three distinct roles: Requester, IT Staff, Administrator.

- Data migration preserving existing Lab 2 tickets, categories, related systems, and attachments.
- IT Staff Ticket Queue with search, filtering (status, priority, owner), sorting, and pagination.
- IT Staff Ticket Detail: Claiming/reassigning tickets, setting IT Priority, workflow status transitions.
- Two-tier discussion thread: Public Comments (visible to all roles) and Internal Notes (restricted to IT Staff and Admin).
- Requester capability to indicate that a problem appears resolved.
- Minimalist Administrator User Management (list, search, role filter, create, edit, activate/deactivate, set initial password, safety rules).
- Automated test suites (Unit, API, UI Component, and Playwright E2E).

Explicitly Excluded

- Email delivery for invitations, password resets, or notifications.
- Self-registration / public sign-up.
- Actions Taken by IT Staff (deferred to Lab 4).
- Formal SLA calculations, automated escalation, and KPI dashboards.
- Multi-tenancy, departments, and extended profile management (avatars, bio).
- Multiple roles assigned to a single user.
- Hard user deletion, bulk user operations, import/export, and account audit history.
- Multi-column sorting and complex multi-filter chaining for the user list.

4. Functional Requirements

- **FR-01**: The system shall authenticate users using email and password credentials.
- **FR-02**: The system shall require users with `mustChangePassword=true` to submit a new password before granting access to application features.
- **FR-03**: The system shall enforce role-based access control (RBAC) across navigation and backend endpoints for Requester, IT Staff, and Administrator.
- **FR-04**: The system shall automatically derive ticket ownership for Requester operations from the authenticated identity, ignoring client-supplied IDs.
- **FR-05**: The system shall provide an IT Staff Ticket Queue supporting keyword search, status/priority/owner filtering, sorting, and pagination.
- **FR-06**: The system shall allow IT Staff and Administrators to open Ticket Detail, claim ownership, or reassign the ticket to another active IT Staff/Admin.
- **FR-07**: The system shall allow IT Staff and Administrators to modify IT Priority independently of the Requester's original Requested Priority.
- **FR-08**: The system shall permit ticket status updates strictly according to the defined lifecycle state machine.
- **FR-09**: The system shall support append-only Public Comments visible to Requesters, IT Staff, and Administrators.
- **FR-10**: The system shall support append-only Internal Notes accessible solely by IT Staff and Administrators.

- **FR-11**: The system shall allow Requesters to indicate that their reported issue appears resolved without formally closing the ticket.
- **FR-12**: The system shall provide an Administrator User Management interface to list, search, filter, create, edit, activate/deactivate accounts, and issue new initial passwords.
- **FR-13**: The system shall let any signed-in user log out and change their own password voluntarily; logout invalidates the session on the server.
- **FR-14**: The system shall show each role only its permitted navigation: Requester ⟶ Create Ticket, My Tickets; IT Staff ⟶ Ticket Queue; Administrator ⟶ User Management, Ticket Queue.

5. Business Rules

Authentication & Account Rules

- **BR-01**: Only active users (`isActive=true`) with valid credentials may authenticate.
- **BR-02**: Users flagged with `mustChangePassword=true` cannot access normal application screens or APIs until a valid new password is saved.
- **BR-03**: Passwords must be securely hashed using bcrypt prior to database persistence; plaintext passwords must never be stored or returned.
- **BR-04**: Email addresses must be unique across all user accounts (case-insensitive check).
- **BR-05**: Session tokens must be invalidated upon logout; subsequent requests with the old token must return 401 Unauthorized.
- **BR-22**: Passwords (self-chosen or set by an Administrator) must be 8–72 characters, contain at least one letter and one number, and not start or end with spaces. A new password must differ from the current one.
- **BR-23**: Changing a password, an Administrator setting a new initial password, or logging out revokes all previously issued tokens for that user. Deactivation and role changes take effect on the user's next request (the server re-reads the user on every request).
- **BR-24**: Invalid credentials and unknown emails return the same generic message. The "account deactivated" message is only shown after a correct password, so account status is not disclosed to guessers.

Ownership & Authorization Rules

- **BR-06**: The authenticated user identity, not any client-supplied requester ID, determines ownership of Requester operations.
- **BR-07**: A Requester may only view and manage tickets and attachments that they own.
- **BR-08**: An IT Staff or Administrator user may view all tickets in the queue and view any ticket detail.
- **BR-09**: Only active IT Staff or Administrator users may be assigned as a ticket's primary owner.
- **BR-25**: When a Requester requests another Requester's ticket, attachment, or comments, the API returns the same 404 Not Found as for a missing record, so it never reveals that the record exists. Role-restricted endpoints (e.g., Internal Notes, staff queue) return 403 Forbidden without any data.
- **BR-26**: The client never supplies identity. `X-Requester-Id` headers and `requesterId` body fields are ignored; requests without a valid bearer token return 401.

- **BR-27**: Creating tickets and managing own attachments are Requester operations. IT Staff and Administrators work on tickets through the staff endpoints and may download (not upload or remove) ticket attachments.

Role Authorization Matrix

Operation / Resource	Requester	IT Staff	Administrator	Notes
Authenticate (Login/Logout/Me)	Allow	Allow	Allow	Must be active user
Change Password (First Login/Self)	Allow	Allow	Allow	Required if `mustChangePassword=true`
Create Ticket	Allow	**Deny (403)**	**Deny (403)**	Requester derived from authenticated session
View Owned Tickets (My Tickets / Detail)	Allow (Own only; others ⟶ 404)	**Deny (403)**	**Deny (403)**	Lab 2 Requester view
Upload / Soft-remove Attachment	Allow (Own only; others ⟶ 404)	**Deny (403)**	**Deny (403)**	Removal requires a reason
Download Attachment	Allow (Own only; others ⟶ 404)	Allow	Allow	Needed for Staff Ticket Detail
View Staff Ticket Queue	**Deny (403)**	Allow	Allow	Staff operational queue
View Staff Ticket Detail	**Deny (403)**	Allow	Allow	Full staff operational detail
Claim / Reassign Ticket Owner	**Deny (403)**	Allow	Allow	Owner must be active Staff or Admin
Update IT Priority	**Deny (403)**	Allow	Allow	Requested Priority remains unchanged
Update Ticket Status	**Deny (403)**	Allow	Allow	Follows permitted transition matrix
Post / View Public Comments	Allow (Own only; others ⟶ 404)	Allow	Allow	Visible to all authorized parties
Post / View Internal Notes	**Deny (403)**	Allow	Allow	Confidential operational notes
Indicate Problem Resolved	Allow (Own only)	**Deny (403)**	**Deny (403)**	Requester flag; does not change status
Admin User Management (CRUD)	**Deny (403)**	**Deny (403)**	Allow	User list, create, edit, deactivate
Admin Reset User Password	**Deny (403)**	**Deny (403)**	Allow	Sets `mustChangePassword=true`

Ticket Status Transition Matrix

Current Status	Permitted Next Statuses	Permitted Roles	Confirmation / Rules
New	`Open`, `Cancelled`	IT Staff, Administrator	Auto-moves to Open when claimed
Open	`In Progress`, `Waiting for Requester`, `Resolved`, `Cancelled`	IT Staff, Administrator	Standard staff triage
In Progress	`Waiting for Requester`, `Resolved`, `Cancelled`	IT Staff, Administrator	Work actively being performed
Waiting for Requester	`In Progress`, `Resolved`, `Cancelled`	IT Staff, Administrator	Awaiting user clarification

Current Status	Permitted Next Statuses	Permitted Roles	Confirmation / Rules
Resolved	`Closed`, `Reopened`	IT Staff, Administrator	Formal resolution by staff
Reopened	`In Progress`, `Resolved`, `Cancelled`	IT Staff, Administrator	Issue recurred or unresolved
Closed	*(None - Terminal State)*	N/A	Ticket lifecycle complete
Cancelled	*(None - Terminal State)*	N/A	Ticket cancelled

Ticket Lifecycle, Priority & Workflow Rules

- **BR-10**: Requested Priority is submitted by the Requester at creation and remains immutable thereafter.
- **BR-11**: IT Priority initially defaults to the Requested Priority value and may subsequently be modified only by IT Staff or Administrator.
- **BR-12**: Valid ticket statuses are: `New`, `Open`, `In Progress`, `Waiting for Requester`, `Resolved`, `Closed`, `Reopened`, `Cancelled`.
- **BR-13**: Permitted status transitions strictly adhere to the Status Transition Matrix above. Invalid transitions must be rejected with 400 Bad Request.
- **BR-14**: A Requester may flag that an issue "appears resolved", but cannot directly transition a ticket to `Resolved` or `Closed`. Formal resolution is reserved for IT Staff or Admin. The flag can be set once (a repeat returns 409) and not on tickets already `Resolved`, `Closed`, or `Cancelled` (400).
- **BR-28**: Staff queue query parameters are validated. Unknown `status`, `priority`, `owner`, `sortBy`, or `sortOrder` values, or search text over 100 characters, return 400 with a message naming the parameter. `page` and `limit` are clamped (page ≥ 1, 1 ≤ limit ≤ 50).

Comments & Internal Notes Rules

- **BR-15**: Public Comments are append-only and visible to Requesters (for owned tickets), IT Staff, and Administrators.
- **BR-16**: Internal Notes are append-only and visible exclusively to IT Staff and Administrators. Non-authorized access attempts must be rejected with 403 Forbidden.
- **BR-17**: Comments and notes must not be empty or whitespace-only, with a maximum length of 2,000 characters (trimmed). Content is stored as plain text and rendered as text by the client (never as HTML), so it cannot inject markup or scripts. Requesters cannot post on `Closed` or `Cancelled` tickets in the UI.

Administrator Safety Rules

- **BR-18**: Administrators manage accounts through deactivation (`isActive=false`); hard deletion of user accounts is prohibited.
- **BR-19**: An Administrator cannot deactivate their own account.
- **BR-20**: The system must prevent deactivating or reassigning the role of the last remaining active Administrator.
- **BR-21**: Setting a new initial password by an Administrator immediately sets `mustChangePassword=true` on the target account and signs that user out of existing sessions.

- **BR-29**: User email addresses must be valid (`name@domain.tld`, max 254 characters); names are required and at most 100 characters. Role must be exactly one of `REQUESTER`, `IT_STAFF`, `ADMINISTRATOR`.

6. UI Specification Summary

- **Design Language**: Zen Green Theme (Primary: `#006B3C`, Secondary: `#0B7A46`, Pale Green: `#EAF6EF`, Background: `#F5F7F6`, Text: `#1A2F25`).
- **Application Shell**: Displays TokTickIT branding, the authenticated user's name and role badge (on all viewports), a **Change Password** action, and a **Logout** button. Role-based navigation renders only destinations authorized for the active user (FR-14). When the server rejects the session (expired or revoked), the user returns to Login with a notice.
- **Login Screen**: Clean, centered Zen Green card with email and password inputs, busy state, validation feedback, and clear error alerts for invalid credentials or inactive accounts.
- **Change Password Screen**: On first login, a mandatory dialog replaces the whole application (no navigation or data loads) until a valid password is saved. The same dialog, with a Cancel button, is used for a voluntary change.
- **Requester Ticket Detail**: Lab 2 details and attachments plus a Public Comments thread and a "My Problem Appears Resolved" action. Internal Notes are never shown.
- **IT Staff Ticket Queue**: Responsive data table / card view featuring search input, status/priority/owner filter dropdowns, sortable headers, pagination controls, and status/priority badges.
- **IT Staff Ticket Detail**: Split-view layout displaying ticket metadata, requester details, ownership claim/reassign controls, IT priority picker, status transition actions, attachment list, and dual-tab discussion feed (Public Comments vs. Internal Notes).
- **User Management Screen**: Administrator table listing Name, Email, Role, Status badge, and Edit button. Includes Search, Role filter, "Create User" modal, "Edit User" modal, and "Set Initial Password" action with safety prompts.
- **Responsive Adaptability**: Fully responsive across Desktop (>=992px), Tablet (768px-991px), and Mobile (<768px).

7. Data Changes

- **Updated `User` Model**:
  - `id`: Int (Primary Key, autoincrement)
  - `email`: String (Unique, indexed)
  - `passwordHash`: String
  - `name`: String
  - `role`: Enum (`REQUESTER`, `IT_STAFF`, `ADMINISTRATOR`)
  - `isActive`: Boolean (default: true)
  - `mustChangePassword`: Boolean (default: false)
  - `tokenVersion`: Int (default: 0) — incremented on logout, password change, and admin password reset to revoke issued tokens

  - `createdAt`, `updatedAt`: DateTime
- **Updated `Ticket` Model**:
  - `requesterId`: Foreign Key referencing `User(id)`
  - `ownerId`: Foreign Key referencing `User(id)`, nullable
  - `itPriority`: Enum (`LOW`, `MEDIUM`, `HIGH`, `URGENT`), defaults to requestedPriority
  - `indicatedResolvedAt`: DateTime, nullable
- **New `PublicComment` Model**:
  - `id`: Int (PK), `ticketId`: Int (FK), `authorId`: Int (FK to `User`), `content`: Text, `createdAt`: DateTime
- **New `InternalNote` Model**:
  - `id`: Int (PK), `ticketId`: Int (FK), `authorId`: Int (FK to `User`), `content`: Text, `createdAt`: DateTime
- **Indexes**: `User.email` (unique), `Ticket.requesterId`, `Ticket.ownerId`, `Ticket.status`, `Attachment.ticketId`, `PublicComment.ticketId`, `InternalNote.ticketId`.
- **Data Migration** (`server/prisma/migrations/20260930120000_lab3_users_roles_workflow/migration.sql`):
  - The Lab 2 `RequesterUser` table is **renamed** to `User` (ids are kept), so every existing `Ticket.requesterId` still points at the same person.
  - Migrated Lab 2 requesters get role `REQUESTER`, the documented local-lab initial password `Welcome123!` (stored only as a bcrypt hash), and `mustChangePassword=true`, so they choose their own password at first login.
  - `TicketPriority` gains `URGENT`. `TicketStatus` becomes the 8 Lab 3 statuses; the Lab 2 value `Pending` maps to `In Progress`.
  - New ticket columns: `ownerId` (nullable, unassigned), `itPriority` (backfilled from `requestedPriority`), `indicatedResolvedAt`. `Attachment.removalReason` is added.
  - New `PublicComment` and `InternalNote` tables.
  - Verified by applying the Lab 1 and Lab 2 migrations to an empty database, inserting Lab 2 data, applying the Lab 3 migration, and confirming preserved rows plus an empty `prisma migrate diff` against `schema.prisma` (MIG-01 in tests.md).
- **Client-side migration**: The Development Requester selector, its `currentRequesterId` state, the `X-Requester-Id` header, and the `/api/requesters` endpoint are removed. The client sends only `Authorization: Bearer <token>`.
- **Idempotent Seed** (`npx prisma db seed`, safe to re-run: users are upserted by email, tickets are created only if their number does not exist):
  - 4 active Requesters, 1 inactive Requester; 3 active IT Staff, 1 inactive IT Staff; 1 active Administrator. Seeding resets these accounts to the documented passwords below.
  - 16 realistic tickets across 4 requesters, all 8 statuses, all 4 priorities, assigned (IT Staff and Administrator) and unassigned, with example Public Comments, Internal Notes, and one resolution indication.

Planned Seed User Accounts

Name	Email	Role	Status	Must Change Password	Default Initial Password
David Lee	`david.lee@example.com`	`REQUESTER`	Active	`false`	`Password123!`
Jennifer Anderson	`jennifer.anderson@example.com`	`REQUESTER`	Active	`false`	`Password123!`
Michael Chang	`michael.chang@example.com`	`REQUESTER`	Active	`false`	`Password123!`
Emily Watson	`emily.watson@example.com`	`REQUESTER`	Active	`true` (Test 1st login)	`Initial123!`
Robert Taylor	`robert.taylor@example.com`	`REQUESTER`	Inactive	`false`	`Password123!`
Sarah Connor	`sarah.connor@example.com`	`IT_STAFF`	Active	`false`	`Password123!`
James Gordon	`james.gordon@example.com`	`IT_STAFF`	Active	`false`	`Password123!`
Elena Rostova	`elena.rostova@example.com`	`IT_STAFF`	Active	`true` (Test 1st login)	`Initial123!`
Marcus Wright	`marcus.wright@example.com`	`IT_STAFF`	Inactive	`false`	`Password123!`
Admin System	`admin@example.com`	`ADMINISTRATOR`	Active	`false`	`Admin123!`

8. API Contract Summary

Full request/response shapes and status codes are in `docs/lab-03/api-spec.md`. All protected endpoints use `Authorization: Bearer <JWT>` and distinguish 401 (not authenticated), 403 (role not permitted or password change required), 400 (invalid input), 404 (missing or not visible), 409 (conflict), and 500 (safe generic message).

- **Authentication**:
  - `POST /api/auth/login`: Authenticate with email and password.
  - `POST /api/auth/logout`: Revoke all of the user's tokens (requires auth).
  - `GET /api/auth/me`: Retrieve current authenticated user profile.
  - `POST /api/auth/change-password`: Set new password, clear `mustChangePassword`, revoke old tokens, and return a fresh token.
- **Requester Tickets (Lab 2 continuity, Requester only)**:
  - `POST /api/tickets`, `GET /api/tickets`, `GET /api/tickets/:id`
  - `POST /api/tickets/:id/attachments`, `DELETE /api/tickets/:id/attachments/:attachmentId`
  - `GET /api/tickets/:id/attachments/:attachmentId/download` (owner, IT Staff, Administrator)
- **IT Staff Queue & Operations**:
  - `GET /api/staff/tickets`: Paginated ticket query with search, filter, and sort params.
  - `GET /api/staff/tickets/:id`: Retrieve detailed ticket view for staff operations.
  - `PATCH /api/staff/tickets/:id/owner`: Claim or assign ticket owner.
  - `PATCH /api/staff/tickets/:id/priority`: Update IT Priority.
  - `PATCH /api/staff/tickets/:id/status`: Transition ticket status.
- **Comments & Notes**:
  - `GET /api/tickets/:id/comments`: Retrieve public comments.

- `POST /api/tickets/:id/comments`: Post public comment.
- `GET /api/tickets/:id/internal-notes`: Retrieve internal notes (IT Staff/Admin only; 403 for Requester).
- `POST /api/tickets/:id/internal-notes`: Post internal note (IT Staff/Admin only).
- `POST /api/tickets/:id/indicate-resolved`: Requester indicates resolution.

- **Administrator User Management**:
  - `GET /api/admin/users`: List users with search and role filter (Admin only).
  - `POST /api/admin/users`: Create user with single role and initial password.
  - `PATCH /api/admin/users/:id`: Edit user name, email, role, or active status.
  - `POST /api/admin/users/:id/reset-password`: Set initial password and require change.

9. Acceptance Criteria

- **AC-01 (Valid Authentication)**: Given an active user with valid email and password, when submitting login, then the system authenticates the user and returns their identity and role.
- **AC-02 (Invalid Credentials)**: Given incorrect password or non-existent email, when attempting login, then access is rejected with a safe error message without disclosing account existence.
- **AC-03 (Inactive Account Block)**: Given an inactive user account (`isActive=false`), when authenticating, then login fails with an inactive account notification.
- **AC-04 (Mandatory Password Change)**: Given a user with `mustChangePassword=true`, when login succeeds, then access to main application screens is blocked until a valid new password is submitted.
- **AC-05 (Session Termination)**: Given an authenticated session, when the user logs out, then session state is destroyed and subsequent protected requests return 401 Unauthorized.
- **AC-06 (Requester Context Resolution)**: Given an authenticated Requester, when performing ticket operations, then ticket ownership is strictly tied to the session identity, ignoring any client-provided `requesterId`.
- **AC-07 (Queue Role Authorization)**: Given an authenticated user, when opening the IT Staff Queue endpoint, then only IT Staff and Administrator users receive 200 OK; Requesters receive 403 Forbidden.
- **AC-08 (Queue Query & Filtering)**: Given tickets in the queue, when IT Staff filter by status, priority, or search keywords, then the returned list contains only matching tickets.
- **AC-09 (Queue Pagination & Sorting)**: Given more tickets than page limit, when navigating pages or toggling sort order, then the correct subset and metadata are returned.
- **AC-10 (Ticket Ownership Assignment)**: Given an open ticket, when an IT Staff member claims or reassigns the ticket, then the ticket's `ownerId` updates and reflects in the queue and detail views.
- **AC-11 (IT Priority Separation)**: Given a ticket with Requested Priority `LOW`, when IT Staff updates IT Priority to `HIGH`, then IT Priority becomes `HIGH` while Requested Priority remains `LOW`.
- **AC-12 (Permitted Status Transitions)**: Given a ticket in status `New`, when transitioning to `Open`, then the update succeeds; when transitioning to an invalid status like `Closed`, then 400 Bad Request is returned.
- **AC-13 (Public Comments)**: Given any authorized participant (Requester owner, Staff, Admin), when posting a public comment, then it appears in the ticket timeline for all roles.

- **AC-14 (Internal Notes Boundary)**: Given a Requester user, when requesting the internal notes endpoint, then access is denied with 403 Forbidden without leaking note content.
- **AC-15 (Requester Resolution Indication)**: Given a Requester viewing their ticket, when clicking "Indicate Problem Resolved", then the indication timestamp is recorded without moving the ticket to `Resolved` status.
- **AC-16 (Admin User Management Authorization)**: Given a non-Admin user, when accessing user management APIs or screens, then access is rejected with 403 Forbidden.
- **AC-17 (User Listing & Search)**: Given an Administrator, when viewing user management, then user accounts are listed and can be filtered by role or searched by keyword.
- **AC-18 (Create User & Duplicate Email Check)**: Given an Administrator creating a user with an already registered email, then creation is rejected with a duplicate email validation error.
- **AC-19 (Account Deactivation)**: Given an active user, when an Admin toggles active status to inactive, then the user cannot authenticate in future sessions; no user record is deleted.
- **AC-20 (Admin Self-Deactivation Prevention)**: Given an logged-in Administrator, when attempting to deactivate their own account, then the request is rejected with a validation error.
- **AC-21 (Last Active Admin Protection)**: Given only one active Administrator remaining in the system, when attempting to deactivate or reassign their role, then the operation is strictly prevented.
- **AC-22 (Admin Set Initial Password)**: Given an Administrator setting a new password for a user, then `mustChangePassword` is set to `true`, forcing the user to change password at next login.
- **AC-23 (Lab 2 Requester Regression)**: Given all Lab 3 changes, when executing Lab 2 ticket creation and attachment tests, then all previous capabilities work without regression.
- **AC-24 (Zen Green Responsive Compliance)**: Given Desktop, Tablet, and Mobile viewports, when loading all screens, then layouts render cleanly without horizontal scrolling, clipping, or visual overlapping.
- **AC-25 (Session Revocation)**: Given a user who changes their password, is given a new initial password, or is deactivated, when an older token is used, then the request returns 401; the fresh token returned by change-password works immediately (including for IT Staff opening the queue).
- **AC-26 (No Existence Disclosure)**: Given a Requester, when requesting another Requester's ticket, attachment, or comments, then the response is the same 404 as for a missing ticket and contains no ticket data.
- **AC-27 (Migration Preserves Lab 2 Data)**: Given a Lab 2 database, when the Lab 3 migration runs, then every Lab 2 requester, ticket, and attachment is preserved with correct ownership and the resulting schema matches `schema.prisma`.
- **AC-28 (Requester Public Comments)**: Given a Requester viewing their own ticket, when they post a Public Comment, then it appears in the thread with author, role, and time; Internal Notes are never shown.
- **AC-29 (Role Navigation)**: Given each role, when the application shell loads, then only that role's permitted navigation is shown (FR-14), and the matching APIs reject other roles (403).
- **AC-30 (Queue Invalid Parameters)**: Given an invalid staff queue parameter, when the queue is requested, then the API returns 400 naming the parameter instead of a server error.

10. Definition of Done

- Complete implementation of approved Functional Requirements (FR-01..14) and Business Rules (BR-01..29).
- Every Acceptance Criterion (AC-01..30) maps to at least one test in `tests.md`; automated tests pass. AC-24 (responsive layout) is verified by the documented visual checklist and screenshots.
- Database migration executes cleanly preserving all Lab 2 records, with idempotent seed script functioning reliably.
- No client-supplied identity is accepted anywhere; no secrets are committed (`JWT_SECRET` comes from `.env`).
- Unit, API integration, UI component, and Playwright E2E automated test suites pass 100% on the `main` branch.
- Conformance to Zen Green UI and responsive design verified across Desktop, Tablet, and Mobile devices with screenshots archived in `artifacts/lab-03/screenshots/`.
- Peer review completed with formal approvals documented in `docs/lab-03/reviewer.md`.
- AI collaboration prompts and reflections documented in `docs/lab-03/ai-use.md`.
- Final PDF submission compiled following strict "Answer Part 1" through "Answer Part 9" formatting.

11. Assumptions and Decisions

- **Session/Auth Mechanism**: Signed JWT (HS256) sent as `Authorization: Bearer <token>`, stored in `localStorage` for this local lab. The token only carries the user id and `tokenVersion`; role, active state, and `mustChangePassword` are re-read from the database on every request. Tokens expire after 8 hours.
- **Logout / Revocation**: Stateless JWTs cannot be deleted, so each user has a `tokenVersion`. Logout, password change, and admin password reset increment it, which invalidates every earlier token for that user (logout therefore signs the user out on all devices — acceptable for this lab).
- **CSRF**: No authentication cookies are used, so browsers never attach credentials automatically and CSRF does not apply. The trade-off is that a script injected into the page could read `localStorage`; this is mitigated by rendering all user content as text (React escaping, no `dangerouslySetInnerHTML`). A production system would prefer an HttpOnly, SameSite cookie with CSRF protection.
- **Secrets**: `JWT_SECRET` is read from `server/.env` (never committed; see `.env.example`). If it is missing, the server generates a random per-process secret, so no fallback secret exists in source control.
- **Password Hashing**: `bcryptjs` with salt rounds = 10. Passwords are limited to 72 characters because bcrypt ignores bytes beyond that.
- **Soft Deactivation**: Hard delete is disabled; `isActive` boolean flag controls authentication validity.
- **Indicate Resolved**: Stored as a timestamp field (`indicatedResolvedAt`) rather than a premature status change to preserve staff operational authority.
- **Role Separation**: IT Staff and Administrators do not use the Requester "Create Ticket" / "My Tickets" functions; Administrators may also work the Ticket Queue (FR-14).
- **Requested Priority options**: Requesters choose Low, Medium, or High in the form; `URGENT` is primarily an IT Priority value (the API accepts it for completeness).

12. Revision History

- **v1.0** (PR #18): Initial Sprint 3 contract, approved before implementation PRs #19–#23.
- **v1.1** (2026-09-30): Hardening revision after a requirements audit. Removed the leftover `X-Requester-Id` identity fallback; added server-side logout/revocation (BR-23), password policy (BR-22), non-disclosure 404s (BR-25), Requester-only ticket routes (BR-27), queue parameter validation (BR-28), the Lab 3 migration details, Requester Public Comments UI, role navigation (FR-13/14), and AC-25..30.

Answer Part 3: Test DD and Traceability

ลิงก์: docs/lab-03/tests.md — แผนการทดสอบครอบคลุม API/Integration, Security/Authorization, Migration, UI Component, E2E, Visual/Responsive และ Accessibility พร้อมตาราง Traceability AC-01–AC-30, path ของไฟล์เทสต์ และผลลัพธ์สุดท้าย

ชุดทดสอบ	เครื่องมือ	ผล
Server: API, security/authorization, Lab 1–2 regression	Vitest + Supertest	**121 / 121 passed**
Client: UI components	Vitest + React Testing Library	**40 / 40 passed**
End-to-end	Playwright (Chromium)	**7 / 7 passed**
Migration (Lab 2 ⟶ Lab 3) และ seed	Prisma migrate + SQL	**Pass** (schema diff ว่าง, ข้อมูล Lab 2 ครบ)
Type-check และ production build	tsc, Vite	**0 errors**

Rendered from docs/lab-03/tests.md

Lab 3 Test Plan and Traceability

1. Test Strategy

The plan was written with the Sprint 3 contract (PR #18) and extended in v1.1 of the specification (see `specification.md` §12) when an audit found security gaps. Every Acceptance Criterion maps to at least one test.

Level	Tool	Location	What it proves
API / integration / security	Vitest + Supertest	`server/tests/lab-0{1,2,3}/`	Endpoints, status codes, authorization, ownership, validation, business rules
Migration	Prisma migrate + SQL	`server/prisma/migrations/`, `server/tests/global-setup.ts`	Lab 2 data survives the Lab 3 migration; migrations build the schema from scratch
UI component	Vitest + React Testing Library	`client/src/tests/`	Rendering, validation messages, role navigation, safe text rendering
End-to-end	Playwright	`e2e/lab-02/`, `e2e/lab-03/`	Real browser journeys against the running app and database
Visual / responsive / accessibility	Playwright capture + checklist	`scripts/capture-screenshots.spec.ts`, `artifacts/lab-03/screenshots/`	Desktop 1280px, tablet 768px, mobile 375px evidence reviewed against §5

Test data isolation: API tests run against a separate database (`<DATABASE_URL name>_test`, or `TEST_DATABASE_URL`). `tests/global-setup.ts` creates it if needed, applies all migrations with `prisma migrate deploy`, and runs the idempotent seed, so the tests never write into development data.

---

2. Planned Tests Matrix

2.1 API, security, and regression tests (server)

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File	Final
API-01	API	AC-01, FR-01	Valid login (email case-insensitive)	200; token + safe user (no `passwordHash`, no `tokenVersion`)	`server/tests/lab-03/auth.api.test.ts`	Pass
API-02	Security	AC-02, BR-24	Wrong password and unknown email	401 with the same generic message	`server/tests/lab-03/auth.api.test.ts`	Pass
API-03	Security	AC-03, BR-01, BR-24	Inactive account; inactive + wrong password	401 "deactivated" only after correct password; otherwise generic	`server/tests/lab-03/auth.api.test.ts`	Pass
API-04	API	AC-04, BR-02	First-login change: blocked before, fresh token after, old token revoked	403 `mustChangePassword` ⟶ 200 with new token ⟶ old token 401	`server/tests/lab-03/auth.api.test.ts`	Pass
API-04b	API	AC-25, BR-23	IT Staff opens queue right after first-login change	403 before, 200 with new token	`server/tests/lab-03/auth.api.test.ts`	Pass
API-04c	Unit/API	BR-22	Password boundaries: 7 chars, no digit, no letter, 73 chars, same as current ⟶ 400; exactly 8 ⟶ 200	As stated	`server/tests/lab-03/auth.api.test.ts`	Pass
API-05	Security	AC-05, BR-05	Logout invalidates the same token; logout without token	`/me` and `/staff` ⟶ 401 after logout; 401 without token	`server/tests/lab-03/auth.api.test.ts`	Pass
API-05b	Security	BR-26	Malformed token; `X-Requester-Id` header alone	401	`server/tests/lab-03/auth.api.test.ts`, `authorization.api.test.ts`	Pass
API-06	Security	AC-06, BR-06	Spoofed `X-Requester-Id` / body `requesterId` with a valid token	Ticket owned by the token's user	`server/tests/lab-03/authorization.api.test.ts`	Pass
API-06b	Security	AC-29, BR-27	Direct API role matrix (Requester / IT Staff / Admin × 4 endpoints); staff cannot create tickets; Requester cannot change owner/priority/status or manage users	Expected 200/403 per role	`server/tests/lab-03/authorization.api.test.ts`	Pass
API-06c	Security	BR-26	Removed `/api/requesters` endpoint	JSON 404	`server/tests/lab-03/authorization.api.test.ts`	Pass
API-07	Security	AC-07	Queue role guard, mustChangePassword guard	200 Staff/Admin; 403 Requester; 403 pending change	`server/tests/lab-03/staff-queue.api.test.ts`	Pass
API-08	API	AC-08, AC-09	Queue search, status/priority/owner filters, sorting, pagination metadata	Matching subsets and correct metadata	`server/tests/lab-03/staff-queue.api.test.ts`	Pass

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File	Final
API-08b	API	AC-30, BR-28	Invalid `status`, `priority`, `owner`, `sortBy`, `sortOrder`; unauthenticated	400 naming the parameter; 401	`server/tests/lab-03/staff-queue.api.test.ts`	Pass
API-09	API	AC-10, BR-09	Claim / reassign / unassign; ineligible owner	200 and `ownerId` updated; New⟶Open on claim; 400 for inactive/requester owner	`server/tests/lab-03/staff-ticket-detail.api.test.ts`	Pass
API-10	API	AC-11, BR-10, BR-11	Update IT Priority; invalid value	IT Priority changes, Requested Priority unchanged; 400	`server/tests/lab-03/staff-ticket-detail.api.test.ts`	Pass
API-11	API	AC-12, BR-13	Permitted and invalid status transitions	200 permitted; 400 invalid (e.g., New⟶Closed, Resolved⟶In Progress)	`server/tests/lab-03/staff-ticket-detail.api.test.ts`	Pass
API-12	API	AC-13, BR-15, BR-17	Public Comments by owner/Staff/Admin; empty; >2000 chars; HTML stored as text	201/200; 400; content returned verbatim	`server/tests/lab-03/comments-notes.api.test.ts`	Pass
API-12b	Security	AC-26, BR-25	Non-owner Requester reads/posts comments; unauthenticated	404 (no data); 401	`server/tests/lab-03/comments-notes.api.test.ts`	Pass
API-13	Security	AC-14, BR-16	Internal Notes for Staff/Admin; Requester read/post	200/201; 403 without note content	`server/tests/lab-03/comments-notes.api.test.ts`	Pass
API-14	API	AC-15, BR-14	Requester indicates resolved; repeat; non-owner; IT Staff; status unchanged	200; 409; 404; 403; status not Resolved	`server/tests/lab-03/staff-ticket-detail.api.test.ts`	Pass
API-15	Security	AC-16	Admin API access guard	200 Admin; 403 Staff and Requester	`server/tests/lab-03/users-admin.api.test.ts`	Pass
API-16	API	AC-17, AC-18, BR-04, BR-29	List/search/role filter; create; duplicate email (case-insensitive); invalid email; invalid role	200/201; 409; 400; 400	`server/tests/lab-03/users-admin.api.test.ts`	Pass
API-17	API	AC-19, BR-18, BR-23	Edit and deactivate; deactivated user's existing token	200, record kept; old token 401	`server/tests/lab-03/users-admin.api.test.ts`	Pass
API-18	API	AC-20, BR-19	Admin self-deactivation	400	`server/tests/lab-03/users-admin.api.test.ts`	Pass
API-19	API	AC-21, BR-20	Deactivate/demote the last active Administrator	400	`server/tests/lab-03/users-admin.api.test.ts`	Pass

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File	Final
API-20	API	AC-22, AC-25, BR-21, BR-22	Set new initial password; policy boundaries; old sessions revoked	200 + `mustChangePassword=true`; 7 chars/no digit 400, 8 chars 200; old token 401	`server/tests/lab-03/users-admin.api.test.ts`	Pass
REG-01	Regression	AC-23, BR-07, BR-27	Lab 2 create ticket (with token, IT Priority copy, invalid priority, 401 without token)	201 / 400 / 401	`server/tests/lab-02/create-ticket.api.test.ts`	Pass
REG-02	Regression	AC-23, AC-26	Lab 2 attachments: upload, size/type limits, 401 unauthenticated, 404 for other requester, Staff download, removal needs reason	As stated	`server/tests/lab-02/attachments.api.test.ts`	Pass
REG-03	Regression	AC-23, AC-06	Lab 2 My Tickets pagination, owner-only list, invalid sortBy	200 / only own tickets / 400	`server/tests/lab-02/my-tickets.api.test.ts`	Pass
REG-04	Regression	AC-23, AC-26	Lab 2 ticket detail: owner 200; other requester and missing ticket both 404	As stated	`server/tests/lab-02/ticket-detail.api.test.ts`	Pass
REG-05	Regression	—	Lab 1 health and categories	200	`server/tests/lab-01/*.test.ts`	Pass

2.2 Migration tests

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Evidence	Final
MIG-01	Migration	AC-27	Apply Lab 1 + Lab 2 migrations to an empty DB, insert Lab 2 rows (2 requesters, tickets in `Pending` / `New`, 1 attachment), apply the Lab 3 migration	Users kept with same ids as `REQUESTER`, bcrypt hash, `mustChangePassword=true`; `Pending` ⟶ `In Progress`; `itPriority` = requested; attachment kept; `prisma migrate diff` vs `schema.prisma` is empty	§6.4 below	Pass
MIG-02	Migration	AC-27	Every test run builds the test DB with `prisma migrate deploy` from the committed history	All 3 migrations apply; suites pass on the result	`server/tests/global-setup.ts`	Pass
MIG-03	Seed	§5.3	Seed runs twice	Second run creates 0 new tickets; accounts reset to documented passwords	§6.4 below	Pass

2.3 UI component tests (client)

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File	Final
UI-01	UI	AC-01, AC-02	Login validation, busy state, error alert	Validation and safe error shown	`client/src/tests/lab-03/Login.test.tsx`	Pass
UI-02	UI	AC-04, BR-22	Change Password: mismatch, short password, success callback	Inline alert; callback only on success	`client/src/tests/lab-03/ChangePassword.test.tsx`	Pass

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File	Final
UI-03	UI	AC-08, AC-09	Staff Queue: badges (IT + requested priority), filters, empty state	Rendered and API called with filters	`client/src/tests/lab-03/StaffTicketQueue.test.tsx`	Pass
UI-04	UI	AC-10–AC-14	Staff Ticket Detail: claim, priority, status buttons, comment/note tabs	Actions call the API; tabs switch	`client/src/tests/lab-03/StaffTicketDetail.test.tsx`	Pass
UI-05	UI	AC-17–AC-22	User Management: list, create, self-deactivation disabled, reset password	As stated	`client/src/tests/lab-03/UserManagement.test.tsx`	Pass
UI-06	UI / Security	AC-04, AC-29, FR-13, FR-14	Role navigation per role, role badge, forced password change hides the app and loads no data, voluntary change can be cancelled, session-expired returns to login	As stated	`client/src/tests/lab-03/AppShell.test.tsx`	Pass
UI-07	UI / Security	AC-28, BR-17	Requester Public Comments: list, empty, post, error, disabled empty post, HTML rendered as text	As stated; no `<img>` injected	`client/src/tests/lab-03/PublicComments.test.tsx`	Pass
UI-08	Regression	AC-23, AC-28, BR-26	Requester detail shows comments, no Internal Notes, "My Problem Appears Resolved"; requests send Bearer token and never `X-Requester-Id`	As stated	`client/src/tests/RequesterTicketDetail.test.tsx`	Pass
UI-09	Regression	AC-23	Lab 2 Create Ticket, My Tickets empty state, attachment section	As in Lab 2	`client/src/tests/{CreateTicket,MyTickets,AttachmentSection}.test.tsx`	Pass

2.4 End-to-end tests (Playwright)

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File	Final
E2E-01a	E2E	AC-01, AC-05, AC-29	Login, role badge and navigation, logout notice, **old token rejected after logout**, reload stays logged out	As stated	`e2e/lab-03/authentication.spec.ts`	Pass
E2E-01b	E2E	AC-02, AC-03	Invalid credentials; inactive account	Safe alerts	`e2e/lab-03/authentication.spec.ts`	Pass
E2E-01c	E2E	AC-04, AC-25	Initial password ⟶ forced change (validation error shown) ⟶ IT Staff queue loads with new session	As stated	`e2e/lab-03/authentication.spec.ts`	Pass
E2E-02	E2E	AC-07, AC-08, AC-10–AC-14	Staff: search queue, claim (New⟶Open), IT Priority, comment, internal note, Open⟶In Progress, invalid targets not offered; API check that Requester gets 403 on notes and Requested Priority unchanged	As stated	`e2e/lab-03/staff-ticket-flow.spec.ts`	Pass
E2E-03	E2E	AC-16–AC-22	Admin: create user, search, self-deactivation guard, set initial password, forced change at next login	As stated	`e2e/lab-03/user-administration.spec.ts`	Pass

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File	Final
E2E-04	E2E / Regression	AC-23, AC-26, AC-28, AC-15	Requester (no selector): create with attachment, list, open, remove with reason, post comment, indicate resolved (status unchanged), another Requester sees "Ticket Unavailable"	As stated	`e2e/lab-02/requester-ticket-flow.spec.ts`	Pass

2.5 Visual, responsive, and accessibility checks

Test ID	Type	Requirement / AC	What It Tests	Evidence	Final
VIS-01	UI style	§7, AC-24	Zen Green tokens, consistent role/status/priority badges, editable vs read-only fields	`artifacts/lab-03/screenshots/**` (desktop)	Pass (checklist §5)
VIS-02	Responsive	AC-24	Login, queue, staff detail, requester detail, user management at 768px and 375px: no clipping or page-level horizontal scroll; phones use card lists	`*-tablet.png`, `*-mobile.png`	Pass (checklist §5)
VIS-03	Accessibility	§7	Labels on inputs, `role="alert"` / `role="status"` feedback, dialog `aria-modal` + title, pagination `aria-label`, keyboard-reachable buttons	Component tests query by label/role (UI-01…UI-08)	Pass

---

3. Acceptance-Criterion Traceability

AC	Description	Covered By
AC-01	Valid authentication & role	API-01, UI-01, E2E-01a
AC-02	Invalid credentials rejection	API-02, UI-01, E2E-01b
AC-03	Inactive account handling	API-03, E2E-01b
AC-04	Mandatory first password change	API-04, UI-02, UI-06, E2E-01c
AC-05	Logout invalidates session	API-05, E2E-01a
AC-06	Requester identity from token	API-06, REG-03
AC-07	Queue role authorization	API-07, E2E-02
AC-08	Queue query & filtering	API-08, UI-03, E2E-02
AC-09	Queue pagination & sorting	API-08, UI-03
AC-10	Claim & reassign ownership	API-09, UI-04, E2E-02
AC-11	IT Priority separation	API-10, UI-04, E2E-02
AC-12	Permitted status transitions	API-11, UI-04, E2E-02
AC-13	Public Comments	API-12, UI-04, E2E-02
AC-14	Internal Notes boundary	API-13, UI-04, E2E-02
AC-15	Requester resolution indication	API-14, UI-08, E2E-04
AC-16	Admin access guard	API-15, E2E-03
AC-17	User listing & filtering	API-16, UI-05, E2E-03
AC-18	Create user & duplicate email	API-16, UI-05, E2E-03
AC-19	Edit & deactivation	API-17, UI-05
AC-20	Self-deactivation prevention	API-18, UI-05, E2E-03

AC	Description	Covered By
AC-21	Last active admin protection	API-19
AC-22	Set new initial password	API-20, UI-05, E2E-03
AC-23	Lab 2 regression	REG-01...REG-04, UI-08, UI-09, E2E-04
AC-24	Responsive Zen Green layout	VIS-01, VIS-02
AC-25	Session revocation	API-04, API-04b, API-17, API-20, E2E-01c
AC-26	No existence disclosure (404)	API-12b, REG-02, REG-04, E2E-04
AC-27	Migration preserves Lab 2 data	MIG-01, MIG-02
AC-28	Requester Public Comments	UI-07, UI-08, E2E-04
AC-29	Role navigation + API enforcement	API-06b, UI-06, E2E-01a
AC-30	Queue invalid parameters	API-08b

---

4. Test Execution Commands

```
# Database (Docker) must be running: docker compose up -d
# 1. Server API / security / regression tests (uses the separate *_test database)
npm --prefix server test

# 2. Client UI component tests
npm --prefix client test

# 3. End-to-end tests (starts server and client automatically)
npx playwright test

# 4. Regenerate responsive screenshots (after `npx prisma db seed` in server/)
npx playwright test --config scripts/screenshots.config.ts

# 5. Direct API authorization evidence with curl (API must be running: npm --prefix server run dev)
bash scripts/api-authorization-evidence.sh
```

Direct API authorization evidence (output of command 5, recorded 2026-10-01):

```
# Ticket TKT-2026-000001 (id=1) belongs to David Lee (Requester)
GET   /api/tickets (no token)                                -> 401 {"error":"Authentication required"}
GET   /api/tickets (only header X-Requester-Id: 1)           -> 401 {"error":"Authentication required"}
GET   /api/tickets/1 (Jennifer, not the owner)               -> 404 {"error":"Ticket not found."}
GET   /api/tickets/1/comments (Jennifer, not the owner)      -> 404 {"error":"Ticket not found"}
GET   /api/tickets/1/internal-notes (David, Requester)       -> 403 {"error":"Access denied: insufficient permissions"}
GET   /api/staff/tickets (David, Requester)                  -> 403 {"error":"Access denied: insufficient permissions"}
PATCH /api/staff/tickets/1/status (David, Requester)         -> 403 {"error":"Access denied: insufficient permissions"}
GET   /api/admin/users (Sarah, IT Staff)                     -> 403 {"error":"Access denied: insufficient permissions"}
POST  /api/tickets/1/indicate-resolved (Sarah, IT Staff)     -> 403 {"error":"Access denied: insufficient permissions"}
GET   /api/tickets/1/internal-notes (Sarah, IT Staff)        -> 200 [{"id":1,"content":"Known GPU driver bug with Thund
erbolt dock firmware. Need to
POST  /api/auth/logout (David)                               -> 200 {"message":"Logged out successfully"}
GET   /api/tickets (David's old token after logout)          -> 401 {"error":"Invalid or expired authentication token"}
```

---

5. Responsive and Visual Checklist

Reviewed on the screenshots in `artifacts/lab-03/screenshots/` (desktop 1280px, tablet 768px, mobile 375px).

- ☑ Consistent Zen Green colour tokens across all new screens.
- ☑ Navigation shows only the current role's destinations (`authentication/08-navigation-*.png`, `user-management/11-non-admin-has-no-user-management.png`).

- ☑ Name and role badge visible in the header on every viewport, including mobile (`authentication/11-navbar-mobile.png`).
- ☑ One shared role badge style (Requester / IT Staff / Administrator) everywhere; status and priority badges readable; queue shows both IT and Requested Priority.
- ☑ Editable inputs vs read-only fields visually distinct (Requested Priority marked "Immutable" in Staff Detail).
- ☑ Validation messages next to the field or at the top of the dialog (`authentication/04b-*`, `user-management/04b-*`, `04c-*`, `06-*`).
- ☑ Public Comments and Internal Notes visually distinguished; Requesters never see Internal Notes.
- ☑ Loading, empty, no-results, success, and safe error feedback present (`staff-queue/07-queue-no-results.png`, `requester-ticket-detail/03-*`, `06-*`).
- ☑ No clipped columns or page-level horizontal scrolling: the queue and user list switch to card layouts under 768px; the desktop queue fits at 1280px.
- ☑ Dialogs fit on mobile.

---

6. Automated Test Execution Results

Recorded on 2026-10-04 on `lab3-staging` at `ae201be` (after merging PR #24), the code released to `main`. Counts are identical to the earlier run on `feature/lab3-7-security-hardening`. Server type-check and client production build also pass. For the PDF (Part 3), add a screenshot of the same commands run on `main` after the release merge.

6.1 Server API, security, and regression tests — 12 files, 121 passed

```
> server@1.0.0 test
> vitest run --no-file-parallelism

 ✓ tests/lab-01/categories.test.ts (1 test)
 ✓ tests/lab-01/health.test.ts (1 test)
 ✓ tests/lab-02/attachments.api.test.ts (7 tests)
 ✓ tests/lab-02/create-ticket.api.test.ts (4 tests)
 ✓ tests/lab-02/my-tickets.api.test.ts (3 tests)
 ✓ tests/lab-02/ticket-detail.api.test.ts (3 tests)
 ✓ tests/lab-03/auth.api.test.ts (22 tests)
 ✓ tests/lab-03/authorization.api.test.ts (11 tests)
 ✓ tests/lab-03/comments-notes.api.test.ts (11 tests)
 ✓ tests/lab-03/staff-queue.api.test.ts (20 tests)
 ✓ tests/lab-03/staff-ticket-detail.api.test.ts (18 tests)
 ✓ tests/lab-03/users-admin.api.test.ts (20 tests)

 Test Files  12 passed (12)
      Tests  121 passed (121)
```

6.2 Client UI component tests — 11 files, 40 passed

```
> client@0.0.0 test
> vitest run

 ✓ src/tests/AttachmentSection.test.tsx (1 test)
 ✓ src/tests/CreateTicket.test.tsx (1 test)
 ✓ src/tests/MyTickets.test.tsx (1 test)
 ✓ src/tests/RequesterTicketDetail.test.tsx (1 test)
 ✓ src/tests/lab-03/AppShell.test.tsx (6 tests)
 ✓ src/tests/lab-03/ChangePassword.test.tsx (4 tests)
 ✓ src/tests/lab-03/Login.test.tsx (4 tests)
```

```
 ✓ src/tests/lab-03/PublicComments.test.tsx (5 tests)
 ✓ src/tests/lab-03/StaffTicketDetail.test.tsx (7 tests)
 ✓ src/tests/lab-03/StaffTicketQueue.test.tsx (5 tests)
 ✓ src/tests/lab-03/UserManagement.test.tsx (5 tests)

 Test Files  11 passed (11)
      Tests  40 passed (40)
```

6.3 End-to-end Playwright tests — 4 files, 7 passed

```
Running 7 tests using 1 worker

  ok 1 [chromium] › e2e\lab-02\requester-ticket-flow.spec.ts › Lab 2 Requester regression with authenticated identity › create, list, open, attach, remove, comment, and indicate resolved as the signed-in Requester
  ok 2 [chromium] › e2e\lab-03\authentication.spec.ts › E2E-01 › AC-01 & AC-05: Authenticate with valid credentials and successfully logout
  ok 3 [chromium] › e2e\lab-03\authentication.spec.ts › E2E-01 › AC-02: Reject invalid login credentials with safe error alert
  ok 4 [chromium] › e2e\lab-03\authentication.spec.ts › E2E-01 › AC-03: Reject inactive user account authentication
  ok 5 [chromium] › e2e\lab-03\authentication.spec.ts › E2E-01 › AC-04: Mandatory password change on first login enforcement
  ok 6 [chromium] › e2e\lab-03\staff-ticket-flow.spec.ts › E2E-02 › Staff triage flow: Queue search, Claim, IT Priority, Comments & Notes, and Status Transition
  ok 7 [chromium] › e2e\lab-03\user-administration.spec.ts › E2E-03 › Admin user journey: User creation, Search/Filter, Self-deactivation guard, and Password Reset login flow

  7 passed
```

6.4 Migration and seed evidence (MIG-01, MIG-03)

```
-- Lab 2 data inserted after migrations 1–2, then Lab 3 migration applied:
 id |        email        |   role    | mustChangePassword | passwordHash
  1 | legacy1@example.com | REQUESTER | t                  | $2b$10$...
  2 | legacy2@example.com | REQUESTER | t                  | $2b$10$...

 ticketNumber |   status    | requestedPriority | itPriority | requesterId
 TKT-L2-1     | In Progress | HIGH              | HIGH       |           2   (was Pending)
 TKT-L2-2     | New         | LOW               | LOW        |           1

 attachments: 1 (preserved)

$ npx prisma migrate diff --from-config-datasource --to-schema prisma/schema.prisma --script
-- This is an empty migration.

$ npx tsx prisma/seed.ts   (second run)
✅ Seeded 0 new Tickets (16 defined) with Public Comments and Internal Notes.
```

ผลการทดสอบบน branch main

```
Terminal — tests on branch: main @ 13e94da

PS C:\Users\Anapat\Downloads\Lab1_Starter_Scaffold\toktickit> git branch --show-current; git log -1 --format="%h %s"
main
13e94da Merge pull request #27 from PpAnpt/lab3-staging

PS C:\Users\Anapat\Downloads\Lab1_Starter_Scaffold\toktickit> npm --prefix server test
> server@1.0.0 test
> vitest run --no-file-parallelism
 RUN  v4.1.10 C:/Users/Anapat/Downloads/Lab1_Starter_Scaffold/toktickit/server
 Test Files  12 passed (12)
      Tests  121 passed (121)
   Start at  16:47:23
   Duration  13.62s (transform 203ms, setup 0ms, import 2.57s, tests 7.25s, environment 1ms)

PS C:\Users\Anapat\Downloads\Lab1_Starter_Scaffold\toktickit> npm --prefix client test
> client@0.0.0 test
> vitest run
 RUN  v4.1.10 C:/Users/Anapat/Downloads/Lab1_Starter_Scaffold/toktickit/client
 Test Files  11 passed (11)
      Tests  40 passed (40)
   Start at  16:47:37
   Duration  4.62s (transform 3.15s, setup 5.23s, import 4.01s, tests 6.60s, environment 28.62s)

PS C:\Users\Anapat\Downloads\Lab1_Starter_Scaffold\toktickit> npx playwright test
Running 7 tests using 1 worker
  ok 1 [chromium] › e2e\lab-02\requester-ticket-flow.spec.ts:16:7 › Lab 2 Requester regression with authenticated identity › create, list, open, attach, remove,
comment, and indicate resolved as the signed-in Requester (10.9s)
  ok 2 [chromium] › e2e\lab-03\authentication.spec.ts:13:7 › E2E-01: Authentication & First-Login Password Change Flow › AC-01 & AC-05: Authenticate with valid
credentials and successfully logout (893ms)
  ok 3 [chromium] › e2e\lab-03\authentication.spec.ts:54:7 › E2E-01: Authentication & First-Login Password Change Flow › AC-02: Reject invalid login credentials with
safe error alert (531ms)
  ok 4 [chromium] › e2e\lab-03\authentication.spec.ts:64:7 › E2E-01: Authentication & First-Login Password Change Flow › AC-03: Reject inactive user account
authentication (486ms)
  ok 5 [chromium] › e2e\lab-03\authentication.spec.ts:75:7 › E2E-01: Authentication & First-Login Password Change Flow › AC-04: Mandatory password change on first
login enforcement (1.1s)
  ok 6 [chromium] › e2e\lab-03\staff-ticket-flow.spec.ts:11:7 › E2E-02: IT Staff Ticket Lifecycle, Operations & Discussion Flow › Staff triage flow: Queue search,
Claim, IT Priority, Comments & Notes, and Status Transition (6.2s)
  ok 7 [chromium] › e2e\lab-03\user-administration.spec.ts:13:7 › E2E-03: Administrator User Administration & Password Reset Lifecycle › Admin user journey: User
creation, Search/Filter, Self-deactivation guard, and Password Reset login flow (1.4s)
  7 passed (22.6s)

PS C:\Users\Anapat\Downloads\Lab1_Starter_Scaffold\toktickit> npx tsc --noEmit -p server
(no errors)

PS C:\Users\Anapat\Downloads\Lab1_Starter_Scaffold\toktickit> npm --prefix client run build
> tsc -b && vite build
vite v8.2.1 building client environment for production...

transforming...✓ 28 modules transformed.
dist/index.html                   0.46 kB │ gzip:  0.30 kB
dist/assets/index-DAHtRjbA.css  234.64 kB │ gzip: 32.14 kB
dist/assets/index-C9dkPUOr.js   283.32 kB │ gzip: 78.25 kB
✓ built in 250ms
```

ผลการรันชุดทดสอบทั้งหมดบน branch main

Answer Part 4: AI Use with Reflection

ลิงก์: docs/lab-03/ai-use.md — LLM ที่ใช้: Google Gemini (ผ่าน Antigravity IDE) สำหรับ specification และ implementation และ Claude Opus 5.5 (ผ่าน Claude Code) สำหรับการตรวจทานเทียบ Lab Sheet และแก้ไขข้อบกพร่อง

Rendered from docs/lab-03/ai-use.md

Lab 3: AI Use Reflection

1. AI Assistant Used

- **LLM / Tool (specification and implementation)**: Google Gemini (via Antigravity IDE)
- **LLM / Tool (requirements audit and hardening)**: Claude Opus 5.5 (via Claude Code in VS Code)

2. Key Prompts Used

Prompt Name	Example Prompt	Purpose
Sprint Specification & Architecture Planning	"ช่วยวิเคราะห์ Lab_03_labsheet.md และจัดทำ Sprint Specification, API Contract, UI Wireframe Design, และ Test Plan ละเอียดให้หน่อย"	กำหนดขอบเขต Architecture, Data Models, Role-Based Access Control (RBAC), และแผนงาน 6 GitHub Issues
Authentication & First-Login Security	"ช่วยออกแบบระบบ Authentication ด้วย bcrypt และ JWT พร้อมกลไกบังคับเปลี่ยนรหัสผ่านครั้งแรก (mustChangePassword)"	สร้าง REST APIs และ UI modal ที่ปลอดภัยตามข้อกำหนดความปลอดภัยของระบบ
Staff Ticket Queue & Lifecycle State Machine	"ช่วยแนะนำการ implement IT Staff Queue พร้อม Search, Filter, Pagination และ Status Transition Machine"	ควบคุมสถานะตั๋ว (New, Open, In Progress, Waiting for Requester, Resolved, Closed, Reopened, Cancelled) ไม่ให้ข้ามขั้นตอนผิดกฎ
Internal Notes vs Public Comments Boundary	"ช่วยออกแบบระบบ Two-Tier Discussion ระหว่าง Public Comments กับ Internal Notes ให้มีสิทธิ์เข้าถึงแยกจากกันอย่างเข้มงวด"	ป้องกันข้อมูลลับของ IT Staff ไม่ให้ Requester มองเห็นทั้งในระดับ API และ Frontend Tab
Administrator User Management & Safety Guards	"ช่วยเขียนระบบ Admin User Management พร้อมป้องกัน Self-Deactivation และ Last Active Admin Protection"	สร้างความปลอดภัยในการจัดการผู้ใช้งาน ป้องกันระบบล็อกตัวเองจากการปิดบัญชีแอดมินคนสุดท้าย
Requirements Audit against the Lab Sheet (Claude)	"can you check all of the work done compared to @Lab_3_sheet.md and make sure every task and requirement are done correctly and neatly"	ตรวจงานทั้งหมดเทียบกับ Lab sheet พบช่องโหว่ เช่น header `X-Requester-Id` ที่ปลอมตัวตนได้, logout ที่ไม่ได้ยกเลิก token จริง, ไม่มี migration ของ Lab 3 และ Requester ยังไม่มีหน้า Public Comments
Fixing the Audit Findings (Claude)	"can you fixes the part that are still needed to fix"	แก้ไขความปลอดภัยฝั่ง server, เพิ่ม migration + test database แยก, เพิ่ม UI ที่ขาด, ปรับ layout มือถือ, เพิ่มเทสต์และอัปเดตเอกสาร
End-to-End Testing with Playwright	"ช่วยเขียน Playwright E2E Tests ทดสอบ User Journey ครบทั้ง Auth, Staff Triage, และ Admin Lifecycle ให้เป็นแบบ Idempotent"	สร้าง Automated E2E Regression ที่รันซ้ำได้อย่างน่าเชื่อถือ ตรวจสอบการทำงานของระบบแบบครบวงจร

3. My Reflection

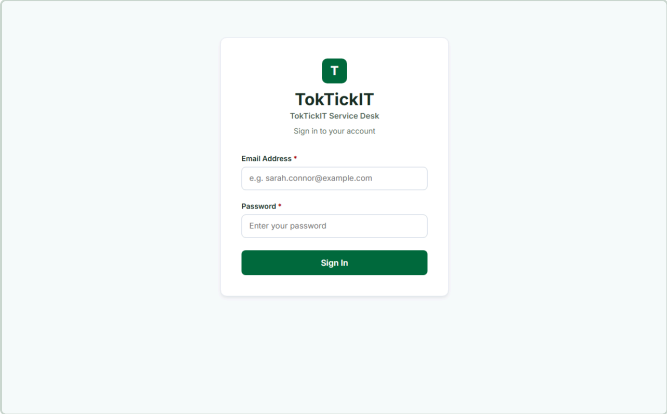
การใช้ Gemini และ Antigravity ใน Lab 3 ช่วยให้การพัฒนาฟีเจอร์ระดับองค์กรที่มีความซับซ้อน (Authentication, RBAC 3 บทบาท, State Machine, และ Admin Safety Rules) เป็นไปอย่างรัดกุมและเป็นระเบียบมากครับ

สิ่งที่เห็นผลชัดเจนที่สุดคือ:

1. **การวาง Test Plan และ TDD ที่ครอบคลุม**: AI ช่วยแนะนำโครงสร้างเทสทั้งระดับ Unit, API Integration, UI Component และ Playwright E2E รวมกันกว่า 160 การทดสอบ (API 121, UI 40, E2E 7 หลังการตรวจทาน) ทำให้ทุกครั้งที่มีการเปลี่ยนโค้ด มั่นใจได้ทันทีว่าไม่มีฟีเจอร์เดิมของ Lab 1 และ Lab 2 พังลง (Zero Regression)
2. **การปฏิบัติตาม Security Best Practices**: AI ช่วยแนะนำการใช้ Password Hashing, Safe User DTO (ไม่ส่ง Password Hash กลับไปที่ Client), Session Invalidation และ Authorization Middleware แยกตามบทบาทอย่างชัดเจน
3. **การพัฒนาแบบ Agile และทีละขั้นตอน**: การแตกงานออกเป็น 6 Issues ย่อยและทำทีละสเต็ป พร้อมการตรวจสอบ Verification ก่อน Merge ทุกครั้ง ทำให้งานเสร็จสิ้นอย่างมีคุณภาพ โค้ดสะอาด และเข้าใจสถาปัตยกรรมของระบบทั้งหมดอย่างลึกซึ้งครับ

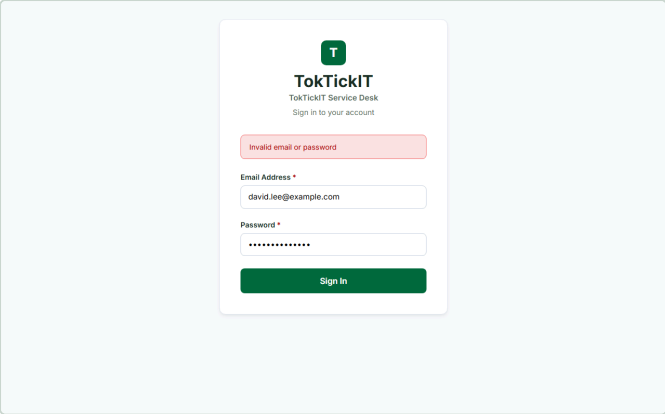
Answer Part 5: Working Login and Password Change UI

- **ข้อความผิดพลาดที่ปลอดภัย:** รหัสผ่านผิดและอีเมลที่ไม่มีในระบบได้ข้อความเดียวกัน ข้อความว่าบัญชีถูกปิดจะแสดงก็ต่อเมื่อรหัสผ่านถูกเท่านั้น (BR-24)
- **สถานะกำลังทำงาน (busy):** ปุ่ม Sign In และ Save New Password เปลี่ยนเป็นข้อความกำลังดำเนินการและถูกปิดระหว่างส่งคำขอ
- **บังคับเปลี่ยนรหัสผ่านครั้งแรก:** หน้าเปลี่ยนรหัสผ่านแทนที่แอปทั้งหมด ไม่โหลดข้อมูลแอปจนกว่าจะบันทึกสำเร็จ และ server ปฏิเสธ API อื่นด้วย 403 (BR-02)
- **Session จริง:** หลังเปลี่ยนรหัสผ่านได้ token ใหม่ และ Logout ยกเลิก token เดิมที่ฝั่ง server (BR-05, BR-23)



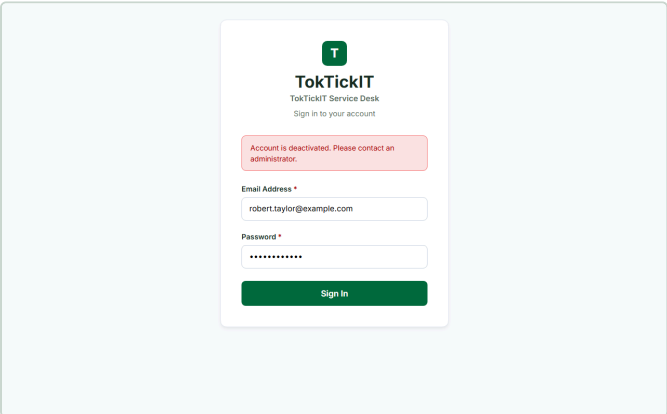
5.1 หน้าจอ Login

`artifacts/lab-03/screenshots/authentication/01-login-desktop.png`



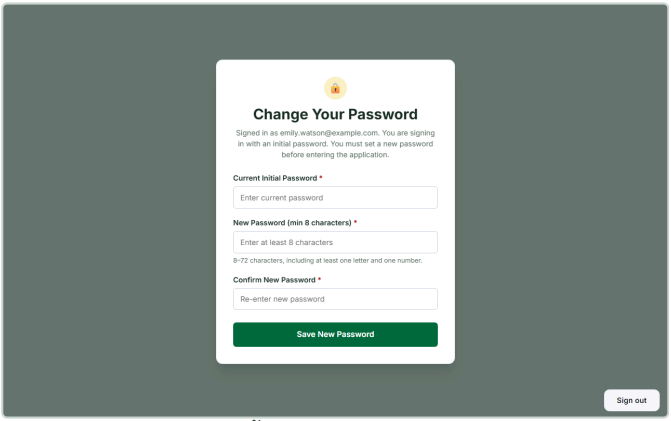
5.2 รหัสผ่านไม่ถูกต้อง: ข้อความที่ปลอดภัย

`artifacts/lab-03/screenshots/authentication/02-login-invalid-credentials.png`



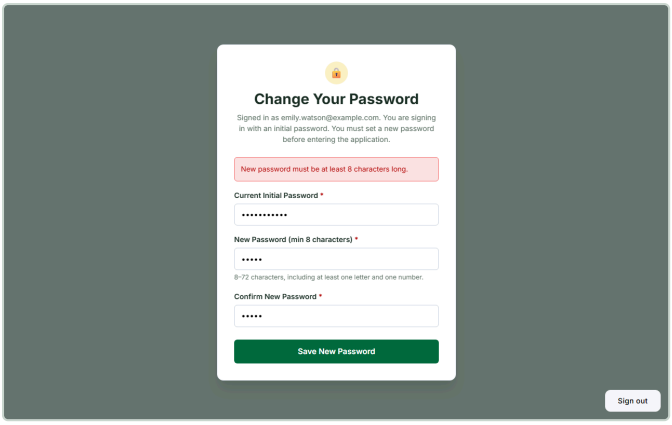
5.3 บัญชีที่ถูกปิดการใช้งาน (Robert Taylor)

`artifacts/lab-03/screenshots/authentication/03-login-inactive-account.png`



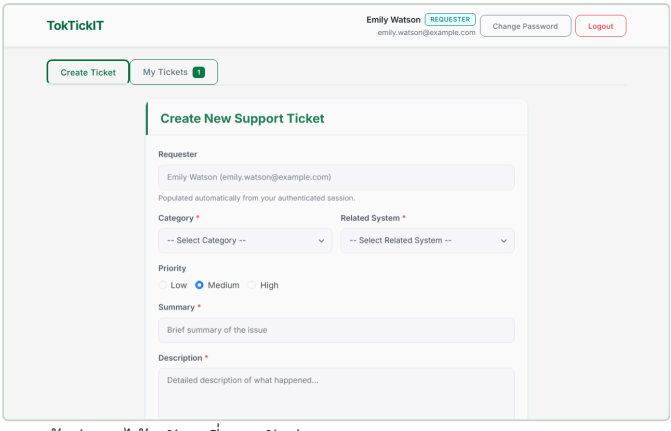
5.4 บังคับเปลี่ยนรหัสผ่านครั้งแรก ไม่มีแอปอยู่ด้านหลัง

`artifacts/lab-03/screenshots/authentication/04-mandatory-password-change.png`



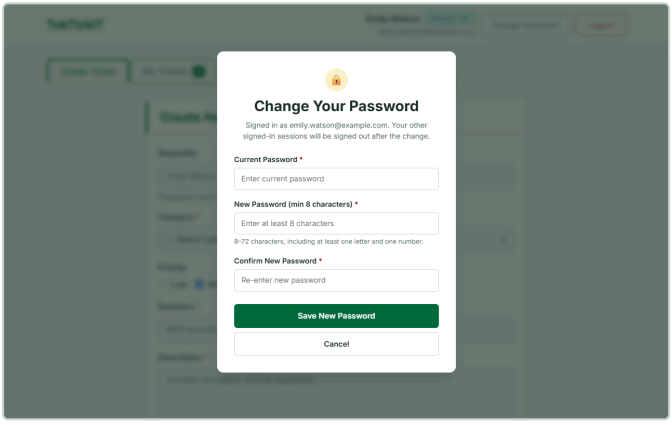
5.5 ตรวจกฎรหัสผ่านใหม่ (8–72 ตัว มีตัวอักษรและตัวเลข)

`artifacts/lab-03/screenshots/authentication/04b-password-validation-error.png`



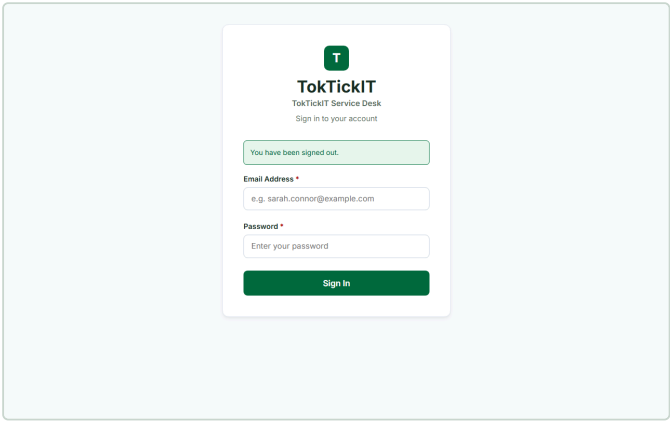
5.6 เข้าสู่แอปได้หลังเปลี่ยนรหัสผ่าน

`artifacts/lab-03/screenshots/authentication/05-after-password-change-logged-in.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



5.7 Change Password ด้วยตนเอง (มีปุ่ม Cancel)

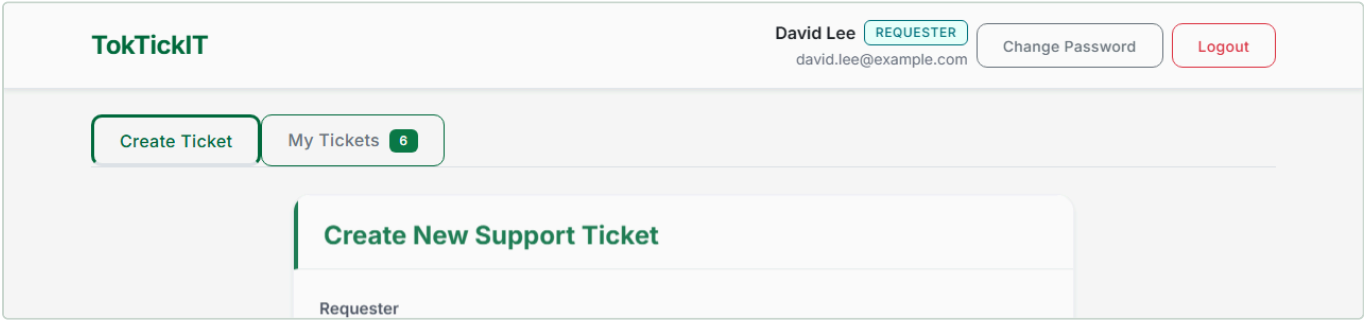
`artifacts/lab-03/screenshots/authentication/06-voluntary-change-password.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



5.8 ออกจากระบบ: "You have been signed out."

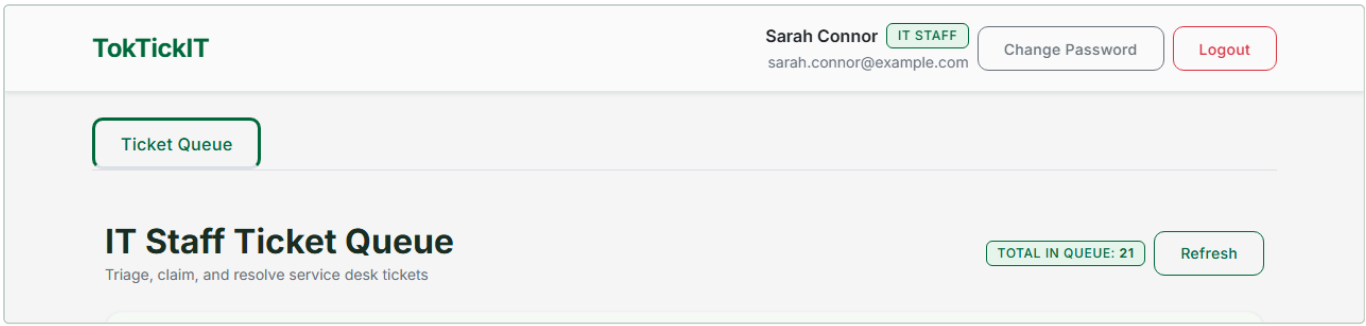
`artifacts/lab-03/screenshots/authentication/07-after-logout.png`

5.9 ชื่อผู้ใช้ บทบาท และเมนูตามบทบาท



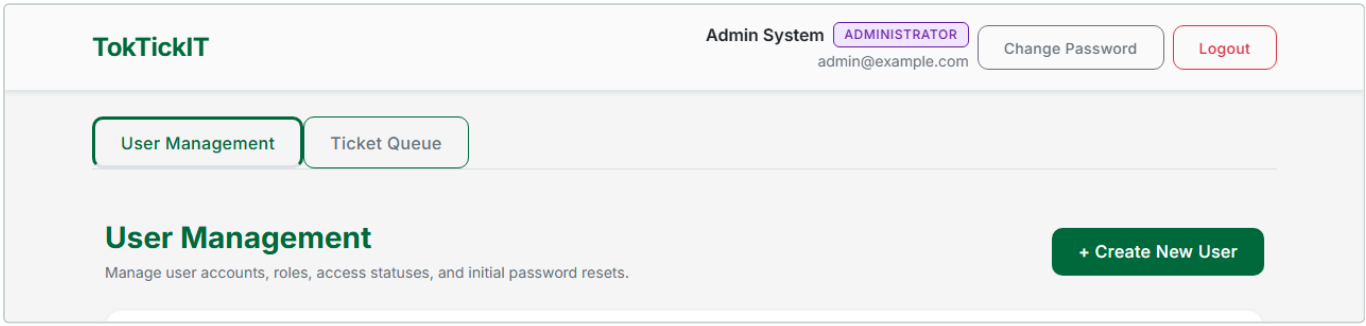
Requester: Create Ticket / My Tickets

`artifacts/lab-03/screenshots/authentication/08-navigation-requester.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



IT Staff: Ticket Queue

`artifacts/lab-03/screenshots/authentication/08-navigation-it-staff.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



Administrator: User Management / Ticket Queue

`artifacts/lab-03/screenshots/authentication/08-navigation-administrator.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`

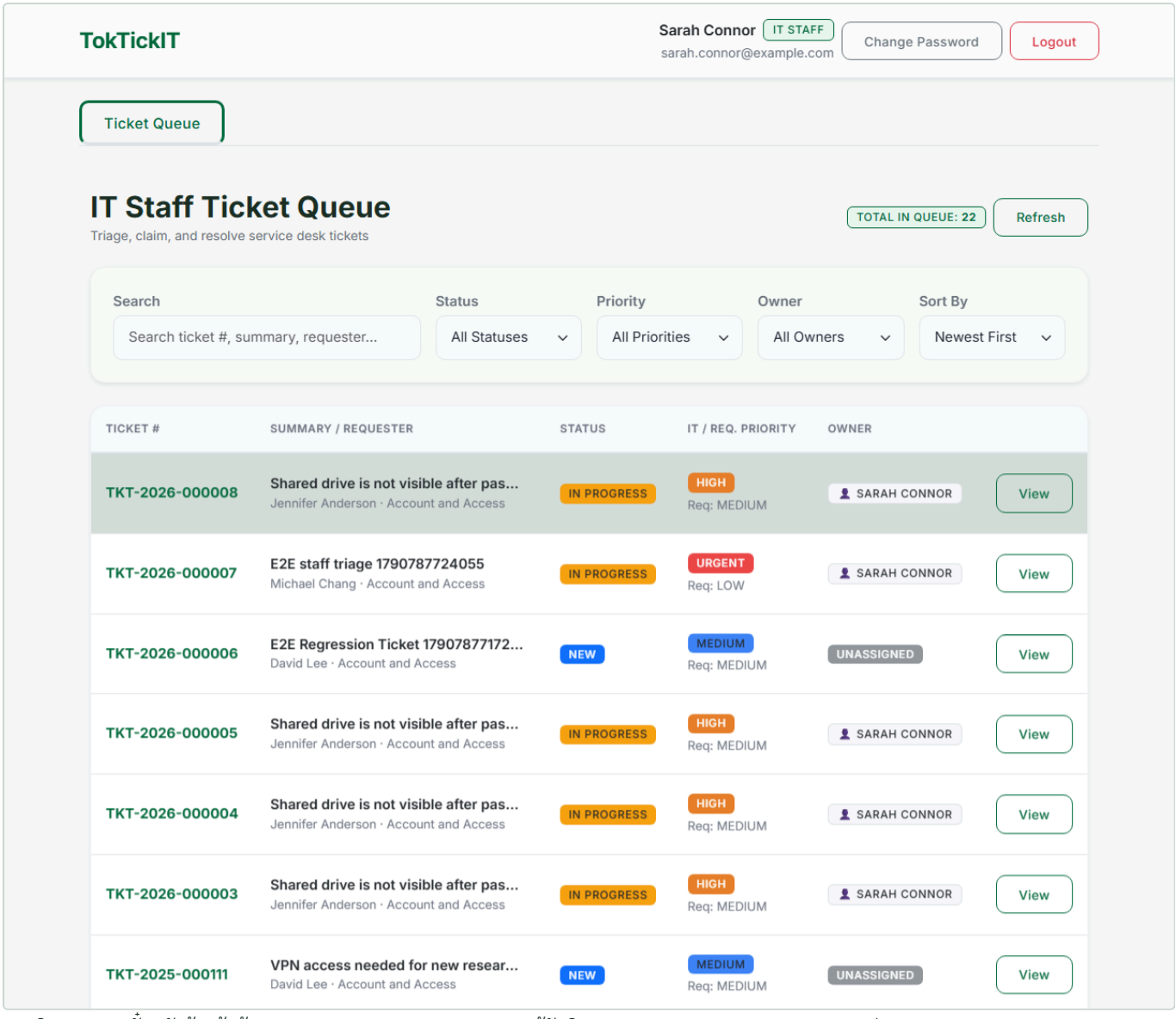
5.10 การเข้าถึงโดยตรงถูกบล็อกหลัง Logout

```
POST  /api/auth/logout (David)                          -> 200 {"message":"Logged out successfully"}
GET   /api/tickets (David's old token after logout)     -> 401 {"error":"Invalid or expired authentication token"}
```

ทดสอบอัตโนมัติด้วย API-05 (`server/tests/lab-03/auth.api.test.ts`) และ E2E-01a (`e2e/lab-03/authentication.spec.ts`) ซึ่ง reload หน้าแล้วยังอยู่ที่หน้า Login

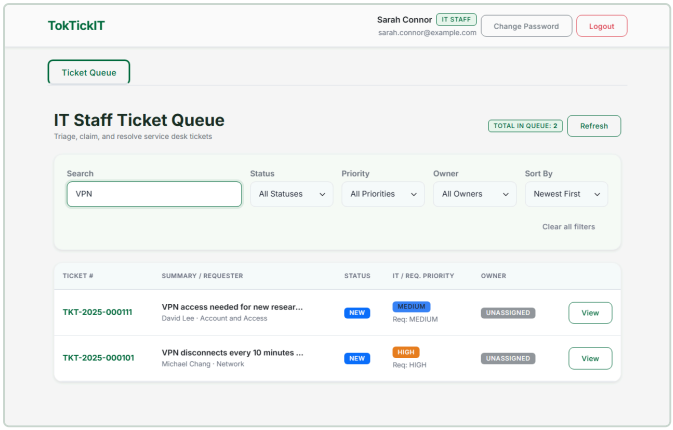
Answer Part 6: Working IT Staff Ticket Queue UI

ข้อมูลตัวอย่างจาก seed มี 16 ตั๋ว ครบทุกสถานะและระดับความสำคัญ ทั้งที่มีและไม่มีผู้รับผิดชอบ คิวรองรับค้นหาด้วยเลขตั๋ว หัวข้อ หรือชื่อผู้แจ้ง, กรองตามสถานะ 8 ค่า / ความสำคัญ / ผู้รับผิดชอบ, เรียงลำดับ, แบ่งหน้าละ 10 รายการ, แสดง IT Priority และ Requested Priority และ server ตอบ 400 เมื่อ query parameter ไม่ถูกต้อง (BR-28)



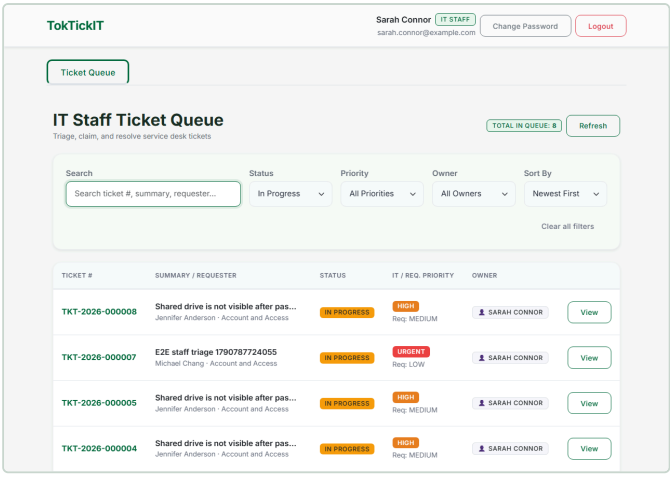
6.1 คิวงาน: เลขตั๋ว, หัวข้อ/ผู้แจ้ง, สถานะ, IT/Requested Priority, ผู้รับผิดชอบ (Assigned/Unassigned) และปุ่ม View

`artifacts/lab-03/screenshots/staff-queue/01-queue-desktop.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



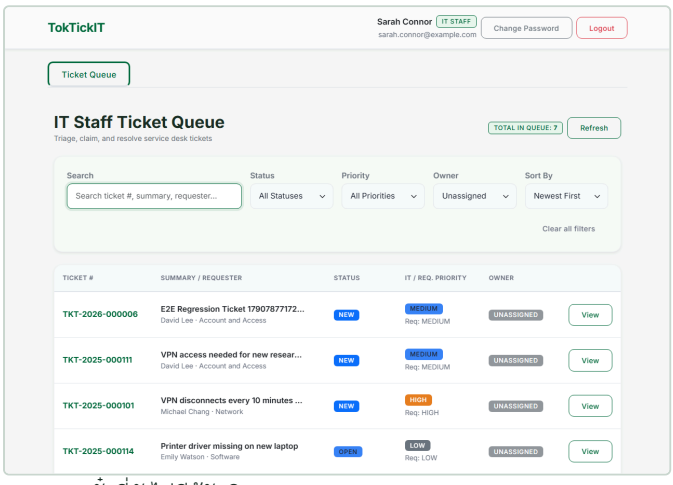
6.2 ค้นหา "VPN"

`artifacts/lab-03/screenshots/staff-queue/02-queue-search-results.png`



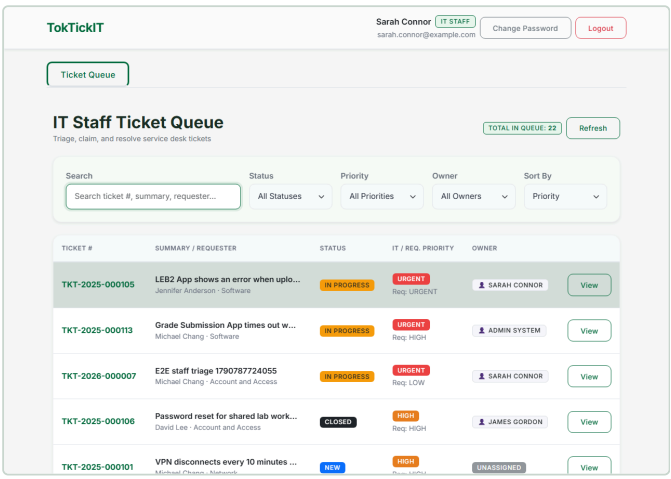
6.3 กรองสถานะ In Progress

`artifacts/lab-03/screenshots/staff-queue/03-queue-filtered-by-status.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



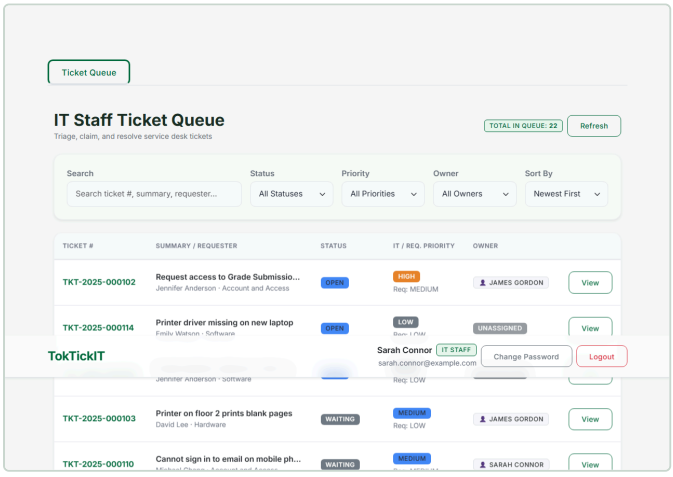
6.4 กรองตั๋วที่ยังไม่มีผู้รับผิดชอบ

`artifacts/lab-03/screenshots/staff-queue/04-queue-unassigned-owner-filter.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



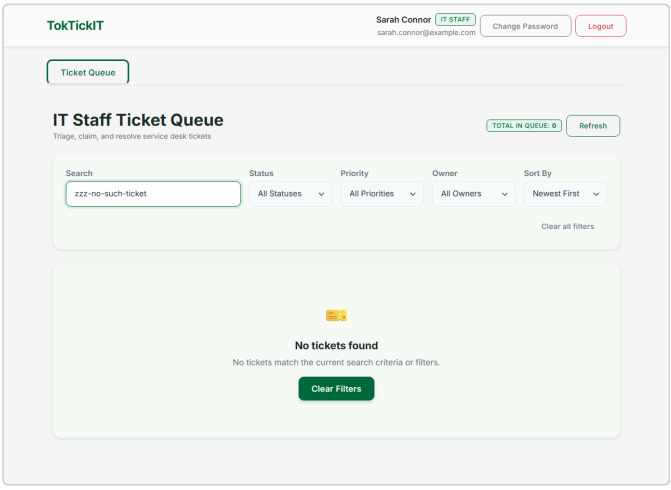
6.5 เรียงตามความสำคัญ

`artifacts/lab-03/screenshots/staff-queue/05-queue-sorted-by-priority.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



6.6 Pagination: หน้า 2 จาก 2

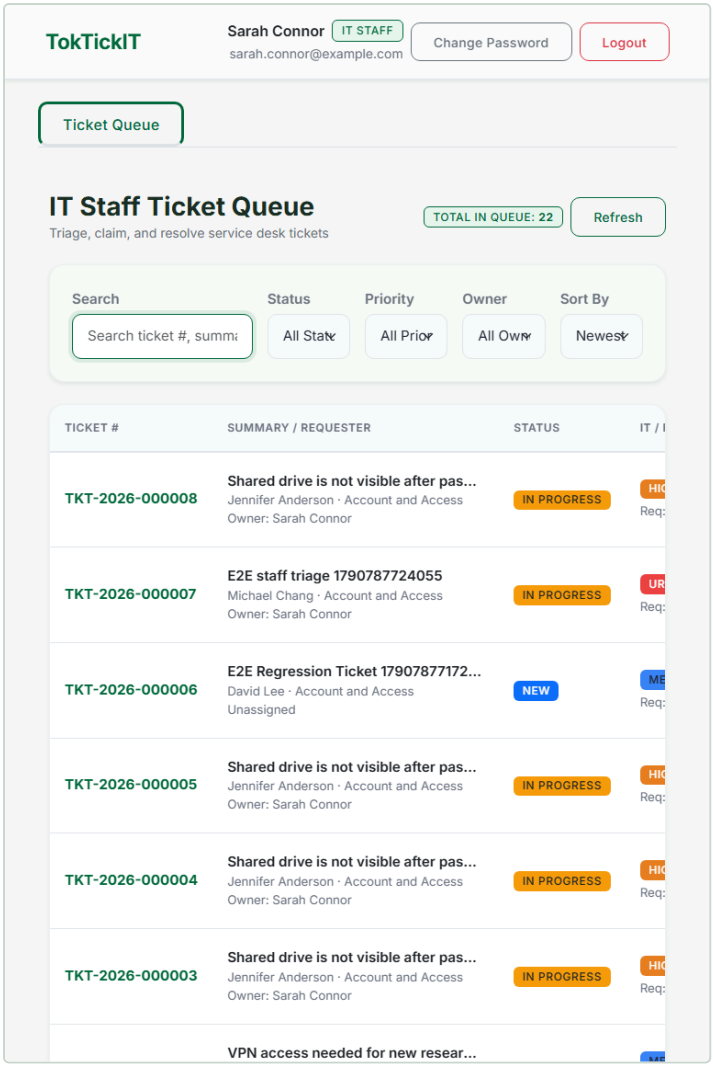
`artifacts/lab-03/screenshots/staff-queue/06-queue-page-2.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



6.7 ไม่พบผลลัพธ์ พร้อมปุ่ม Clear Filters

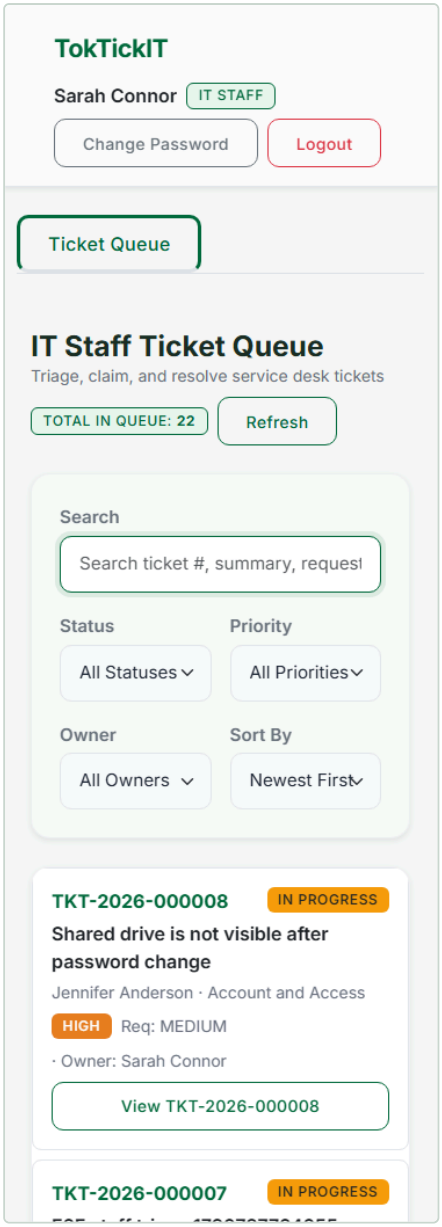
`artifacts/lab-03/screenshots/staff-queue/07-queue-no-results.png`

สถานะ loading และข้อความผิดพลาดที่ปลอดภัยเมื่อโหลดคิวไม่สำเร็จทดสอบใน UI-03 (`client/src/tests/lab-03/StaffTicketQueue.test.tsx`)



6.8 Tablet 768px: ตารางกระชับ ยังเห็นปุ่ม View

`artifacts/lab-03/screenshots/staff-queue/08-queue-tablet.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`

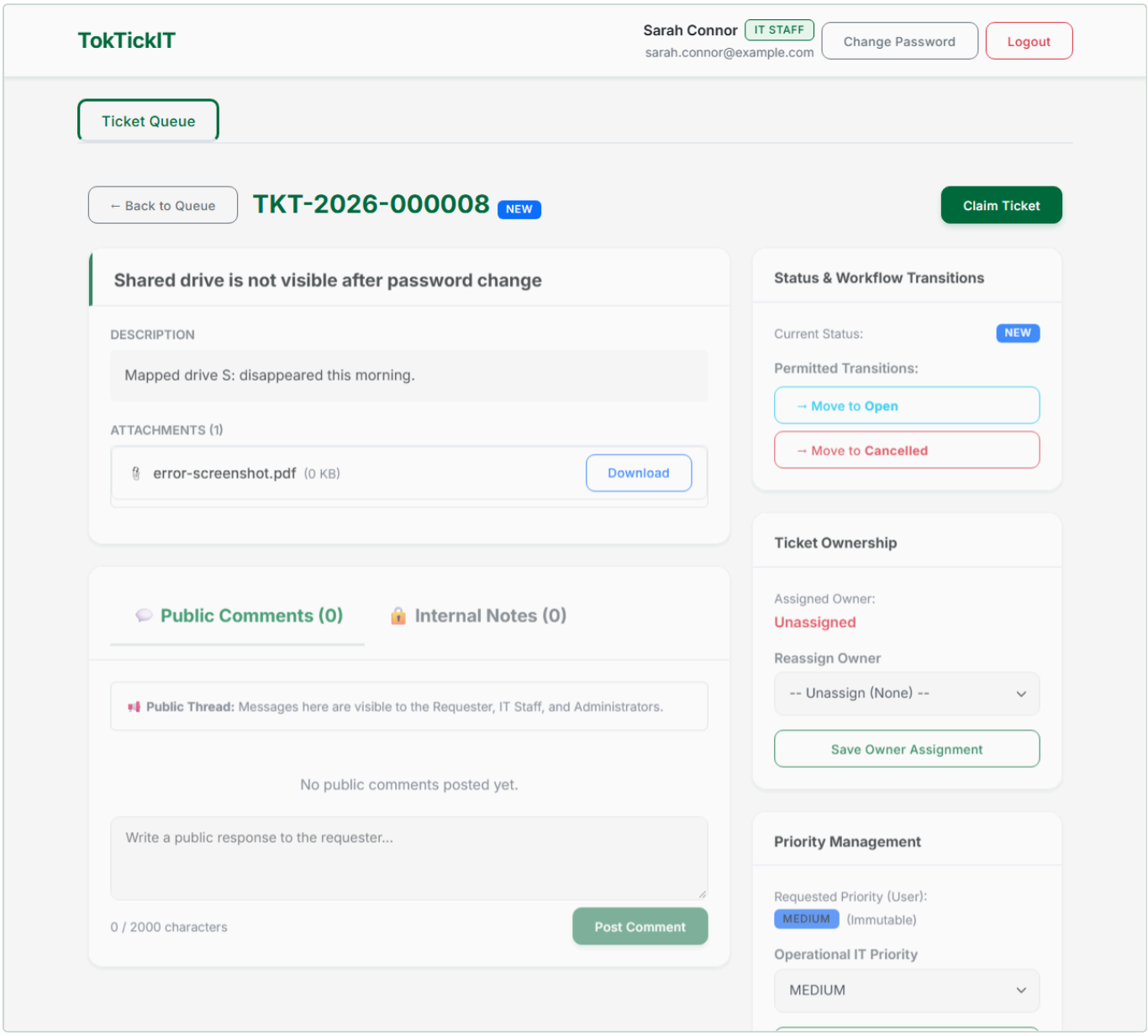


6.9 Mobile 375px: แสดงเป็นการ์ด ไม่มีการเลื่อนแนวนอน

`artifacts/lab-03/screenshots/staff-queue/09-queue-mobile.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`

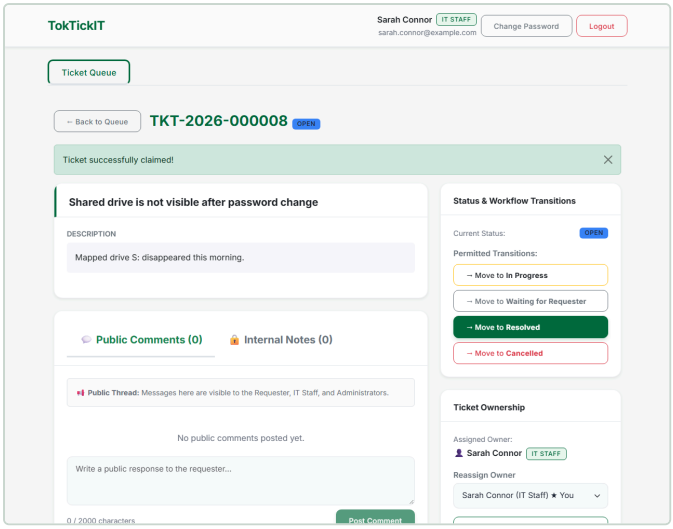
Answer Part 7: Working IT Staff Ticket Detail UI

- **Claim / Reassign:** Claim ตั้งตัวเองเป็นผู้รับผิดชอบ และตั๋ว New เปลี่ยนเป็น Open อัตโนมัติ ส่วน Reassign เลือกได้เฉพาะ IT Staff/Administrator ที่ active (BR-09)
- **IT Priority:** ปรับได้อิสระ Requested Priority แสดงเป็น "Immutable" (BR-10, BR-11)
- **สถานะ:** ปุ่มแสดงเฉพาะสถานะถัดไปที่อนุญาต และ server ปฏิเสธการเปลี่ยนที่ไม่อนุญาตด้วย 400 (BR-13)
- **Public Comments / Internal Notes:** append-only จำกัด 2,000 ตัวอักษร และแสดงเป็นข้อความธรรมดา (BR-15–BR-17)
- **ไฟล์แนบต่อเนื่องจาก Lab 2:** IT Staff ดาวน์โหลดไฟล์แนบได้ด้วย token ที่ยืนยันตัวตนแล้ว
- **Requester ระบุว่าปัญหาแก้แล้ว:** เจ้าหน้าที่เห็นการแจ้ง แต่สถานะตั๋วไม่เปลี่ยนเอง (BR-14)



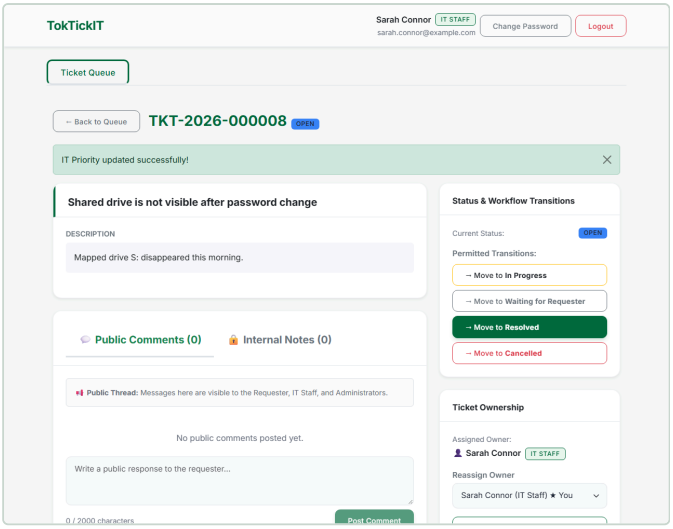
7.1 Ticket Detail ก่อน Claim: รายละเอียด, ไฟล์แนบ, การ์ด Status/Ownership/Priority

`artifacts/lab-03/screenshots/staff-ticket-detail/01-ticket-detail-before-claim.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



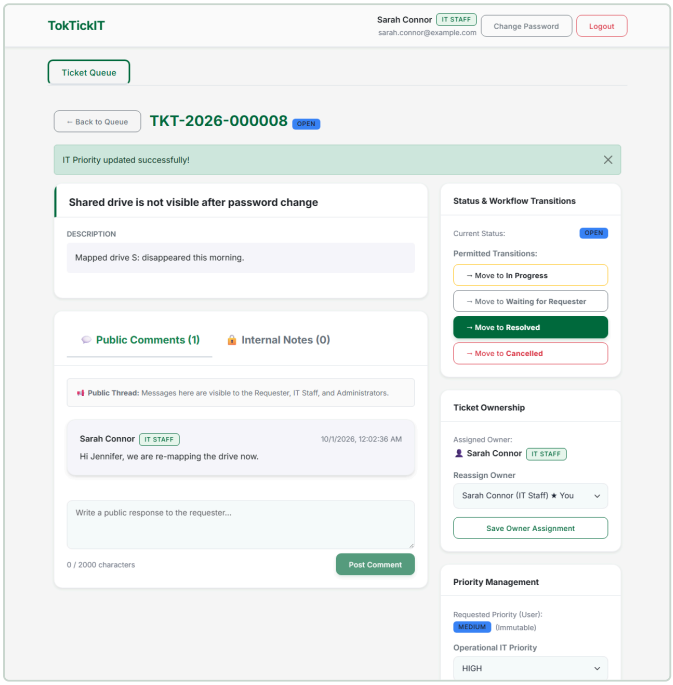
7.2 หลัง Claim: New ⟶ Open

`artifacts/lab-03/screenshots/staff-ticket-detail/02-after-claim-status-open.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



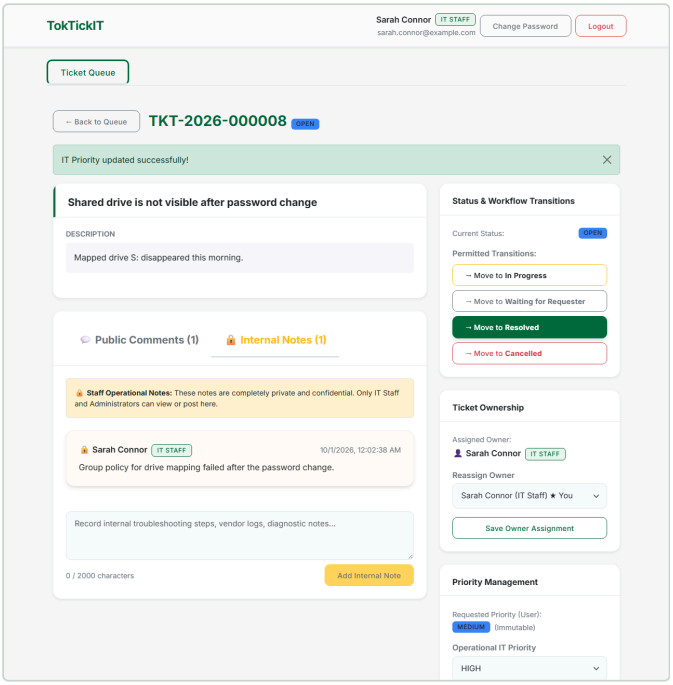
7.3 IT Priority = HIGH, Requested = MEDIUM

`artifacts/lab-03/screenshots/staff-ticket-detail/03-it-priority-updated.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



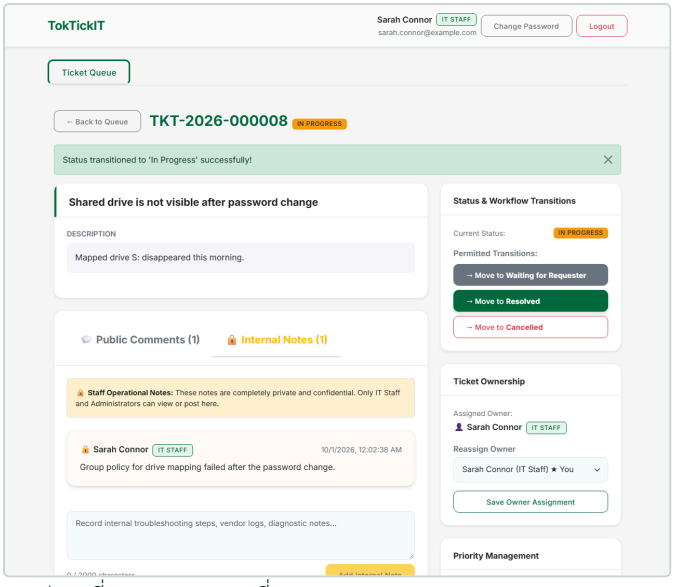
7.4 Public Comments

`artifacts/lab-03/screenshots/staff-ticket-detail/04-public-comments.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



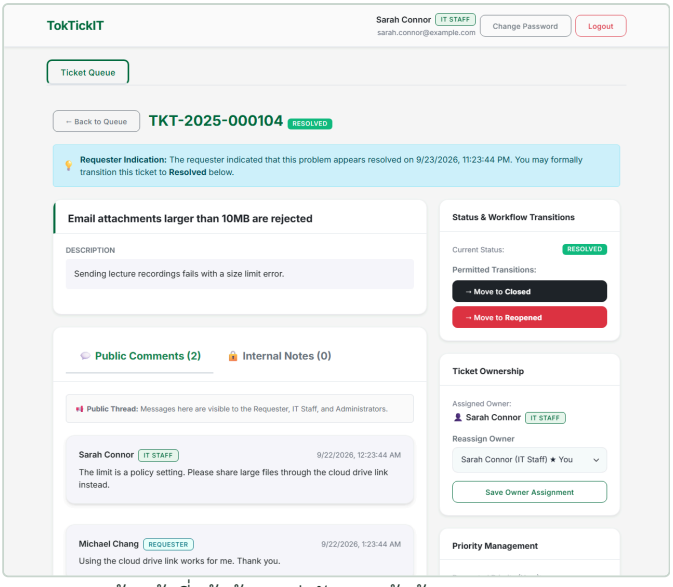
7.5 Internal Notes (การ์ดสีเหลือง มีไอคอนแม่กุญแจ)

`artifacts/lab-03/screenshots/staff-ticket-detail/05-internal-notes.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



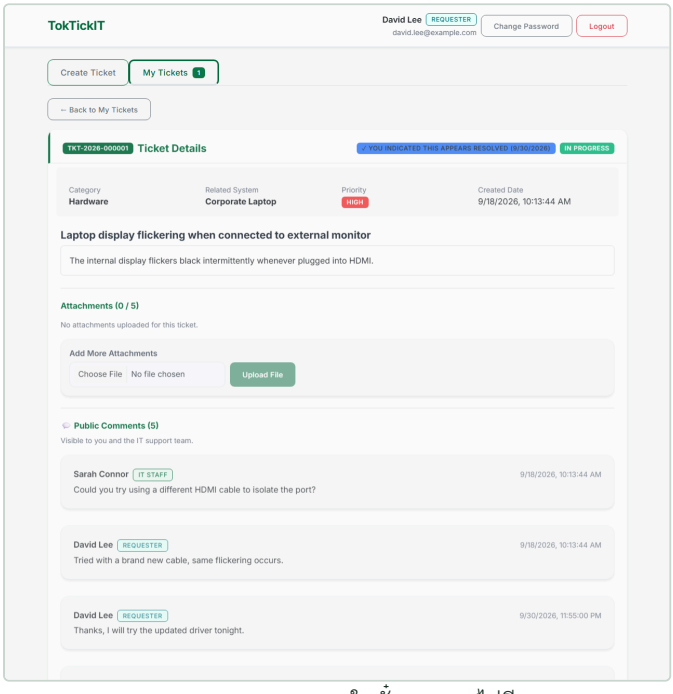
7.6 ปุ่มเปลี่ยนสถานะเฉพาะที่อนุญาต

`artifacts/lab-03/screenshots/staff-ticket-detail/06-status-transition-in-progress.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



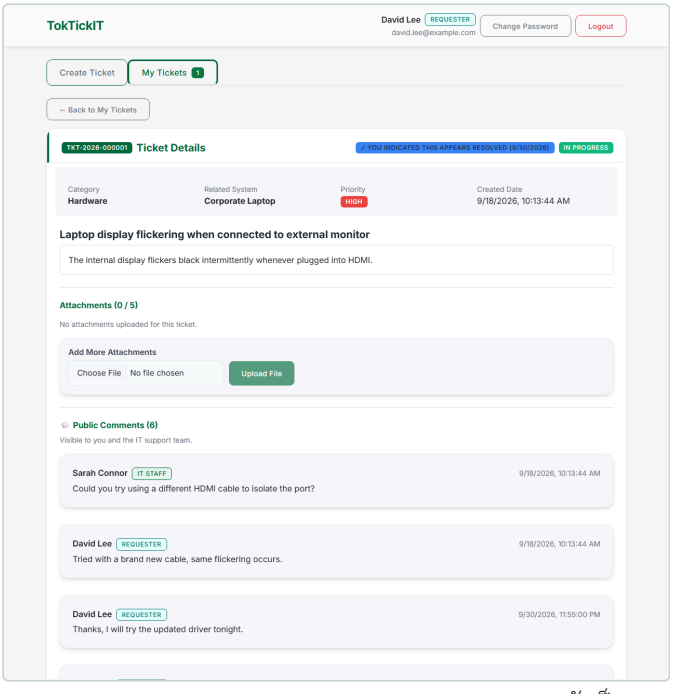
7.7 มุมมองเจ้าหน้าที่: ผู้แจ้งระบุว่าปัญหาแก้แล้ว

`artifacts/lab-03/screenshots/staff-ticket-detail/09-requester-resolution-indicated.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



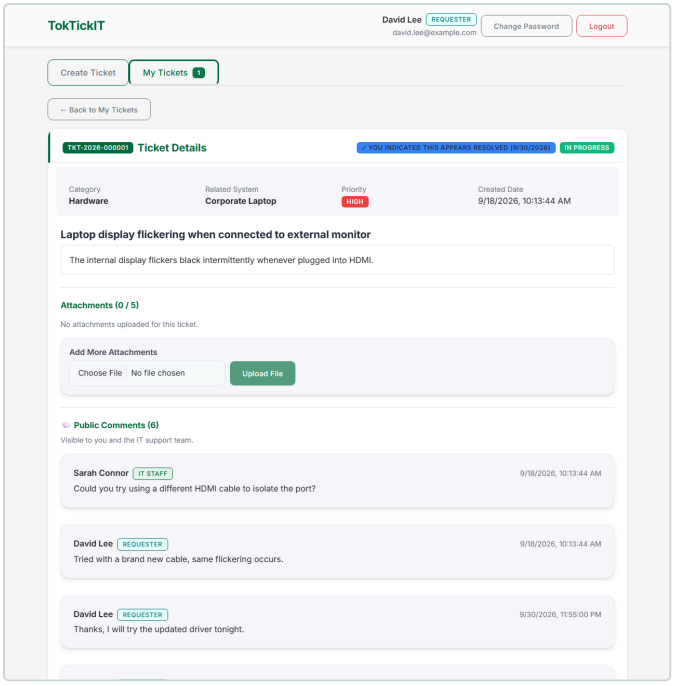
7.8 Requester: Public Comments ในตั๋วของตน (ไม่มี Internal Notes)

`artifacts/lab-03/screenshots/requester-ticket-detail/02-detail-with-public-comments.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



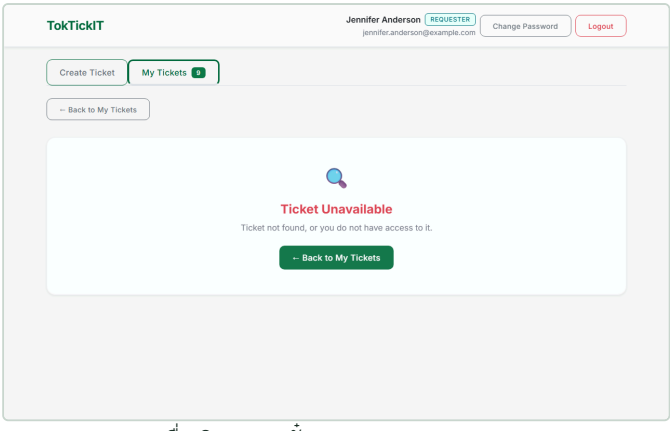
7.9 Requester: "My Problem Appears Resolved" สถานะยังเป็น In Progress

`artifacts/lab-03/screenshots/requester-ticket-detail/04-problem-appears-resolved.png — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



7.10 Requester โพสต์ความคิดเห็นสำเร็จ

`artifacts/lab-03/screenshots/requester-ticket-detail/03-comment-posted.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



7.11 Requester อื่นเปิด URL ตั๋ว: "Ticket Unavailable"

`artifacts/lab-03/screenshots/requester-ticket-detail/06-other-requesters-ticket-unavailable.png`

7.12 หลักฐานการตรวจสิทธิ์ที่ API โดยตรง (Direct API Authorization)

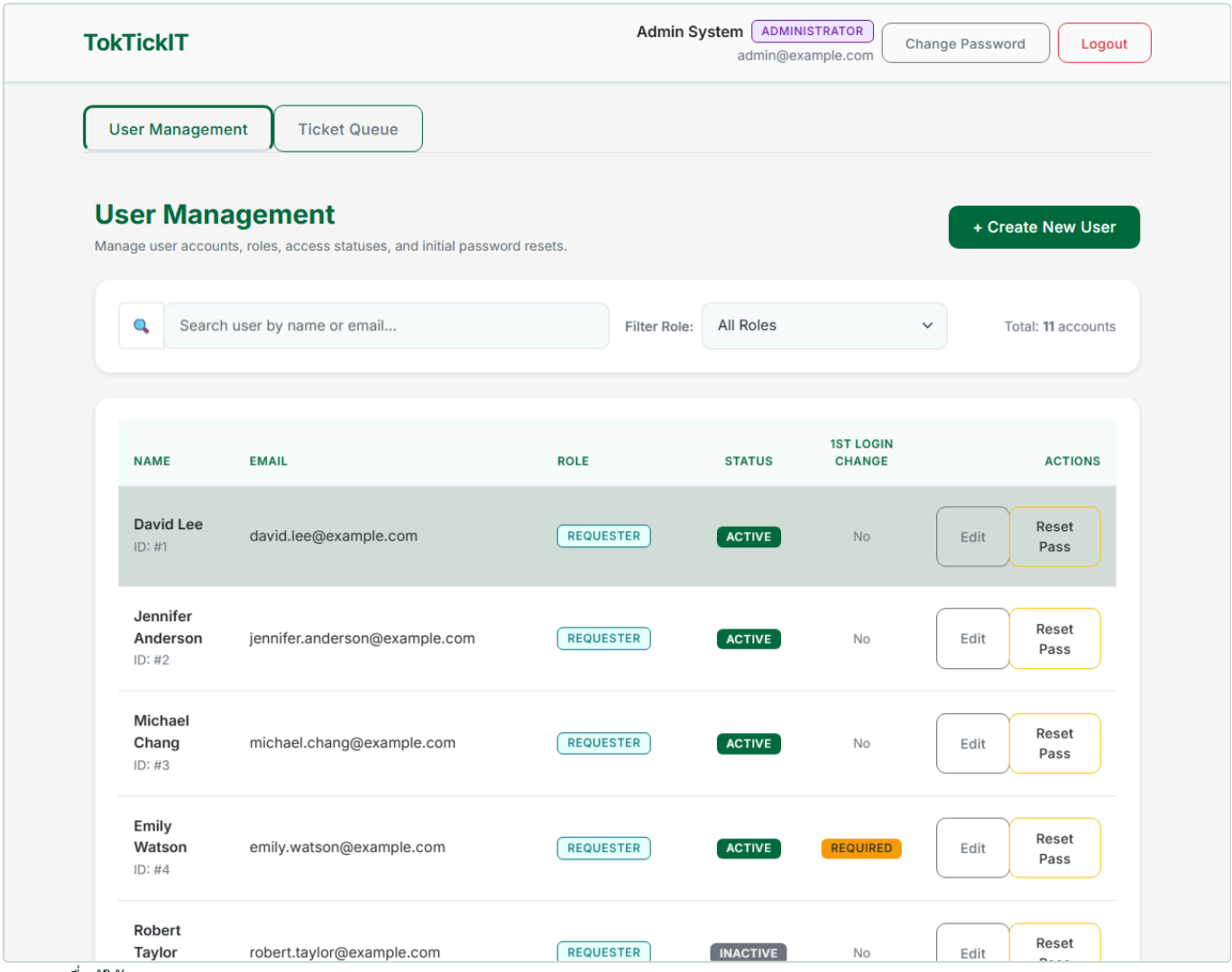
ผลจริงจากการเรียก API ด้วย curl โดยไม่ผ่าน UI (`bash scripts/api-authorization-evidence.sh`):

```
# Ticket TKT-2026-000001 (id=1) belongs to David Lee (Requester)
GET   /api/tickets (no token)                                -> 401 {"error":"Authentication required"}
GET   /api/tickets (only header X-Requester-Id: 1)           -> 401 {"error":"Authentication required"}
GET   /api/tickets/1 (Jennifer, not the owner)               -> 404 {"error":"Ticket not found."}
GET   /api/tickets/1/comments (Jennifer, not the owner)      -> 404 {"error":"Ticket not found"}
GET   /api/tickets/1/internal-notes (David, Requester)       -> 403 {"error":"Access denied: insufficient permissions"}
GET   /api/staff/tickets (David, Requester)                  -> 403 {"error":"Access denied: insufficient permissions"}
PATCH /api/staff/tickets/1/status (David, Requester)         -> 403 {"error":"Access denied: insufficient permissions"}
GET   /api/admin/users (Sarah, IT Staff)                     -> 403 {"error":"Access denied: insufficient permissions"}
POST  /api/tickets/1/indicate-resolved (Sarah, IT Staff)     -> 403 {"error":"Access denied: insufficient permissions"}
GET   /api/tickets/1/internal-notes (Sarah, IT Staff)        -> 200 [{"id":1,"content":"Known GPU driver bug with Thunderbolt
dock…
POST  /api/auth/logout (David)                               -> 200 {"message":"Logged out successfully"}
GET   /api/tickets (David's old token after logout)          -> 401 {"error":"Invalid or expired authentication token"}
```

- **401:** ไม่มี token หรือ token ถูกยกเลิก header `X-Requester-Id` ไม่ถูกใช้เป็นตัวตน
- **403:** มี token แต่บทบาทไม่มีสิทธิ์ และไม่มีข้อมูลส่งกลับ
- **404:** Requester เปิดตั๋วของผู้อื่นได้ผลเหมือนตั๋วที่ไม่มีอยู่ จึงไม่รู้ว่าตั๋วนั้นมีจริง (BR-25)
- ทดสอบอัตโนมัติแบบตารางสิทธิ์ทุกบทบาทใน `server/tests/lab-03/authorization.api.test.ts` (API-06b)

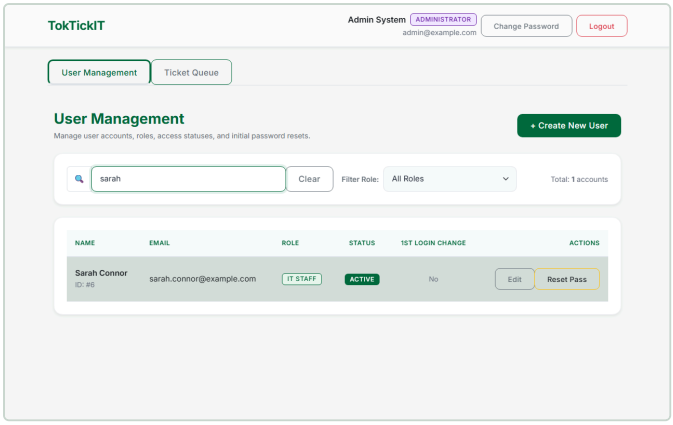
Answer Part 8: Working Administrator User Management UI

ข้อกำหนด	หลักฐาน
รายชื่อผู้ใช้: Name, Email, Role, Status, Edit	8.1
ค้นหาด้วยชื่อหรืออีเมล / กรองตามบทบาท	8.2, 8.3
สร้างผู้ใช้ 1 บทบาท พร้อมรหัสผ่านเริ่มต้น	8.4
อีเมลซ้ำ (409) และข้อมูลไม่ถูกต้อง	8.5, 8.6
แก้ไขชื่อ อีเมล บทบาท และสถานะ active	8.7
ตั้งรหัสผ่านเริ่มต้นใหม่และบังคับเปลี่ยนตอนล็อกอินครั้งถัดไป	8.8 และ E2E-03 (ล็อกอินด้วยรหัสใหม่แล้วถูกบังคับเปลี่ยน ดู 5.4)
ห้ามปิดบัญชีตัวเอง (BR-19) / ห้ามปิดหรือเปลี่ยนบทบาท Admin คนสุดท้าย (BR-20)	8.9, 8.10
ผู้ที่ไม่ใช่ Admin เข้าถึงไม่ได้ (ไม่มีเมนู และ API ตอบ 403)	8.11 และ Part 7.12
Responsive Zen Green และข้อความผิดพลาดที่ปลอดภัย	8.12, 8.13



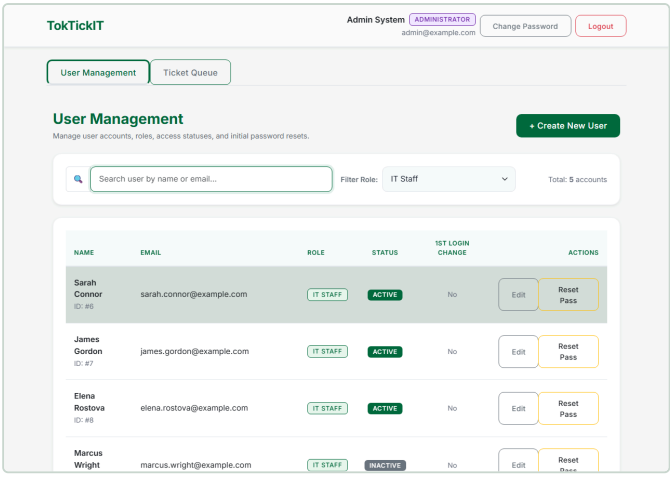
8.1 รายชื่อผู้ใช้

`artifacts/lab-03/screenshots/user-management/01-user-list-desktop.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



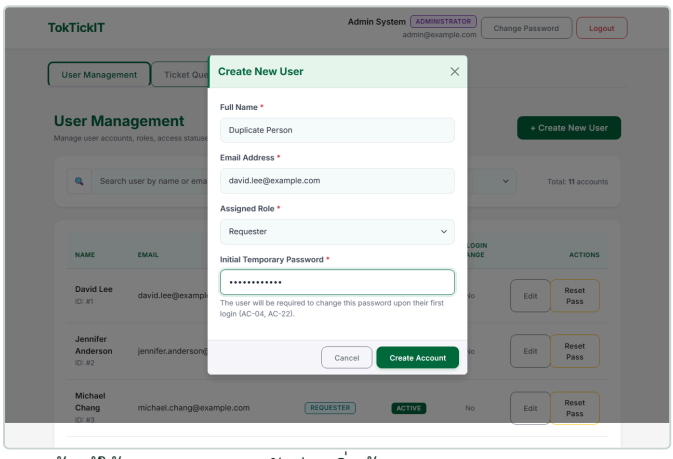
8.2 ค้นหา "sarah"

`artifacts/lab-03/screenshots/user-management/02-user-search.png`



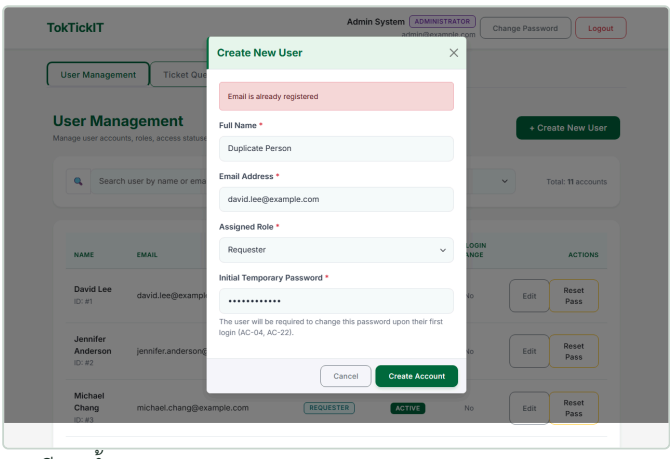
8.3 กรองบทบาท IT Staff

`artifacts/lab-03/screenshots/user-management/03-filter-by-role.png – แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



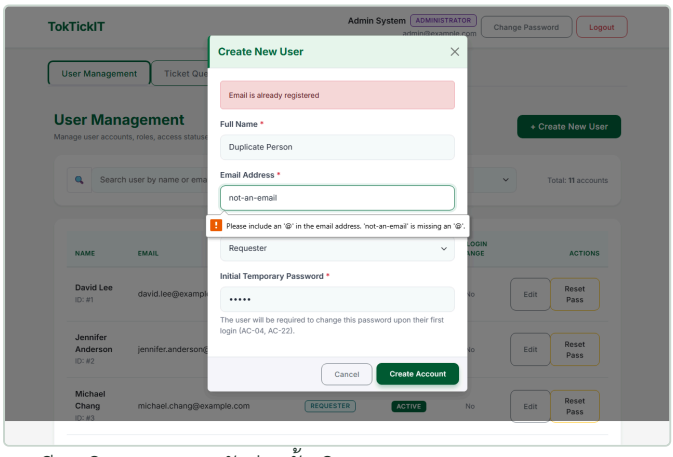
8.4 สร้างผู้ใช้: 1 บทบาท + รหัสผ่านเริ่มต้น

`artifacts/lab-03/screenshots/user-management/04-create-user-modal.png – แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



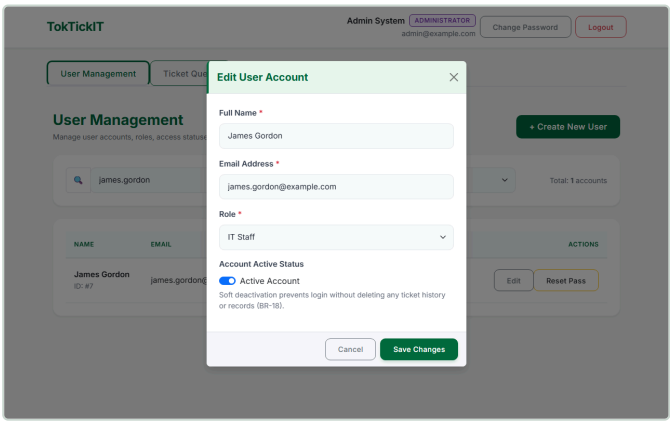
8.5 อีเมลซ้ำ (409)

`artifacts/lab-03/screenshots/user-management/04b-duplicate-email-validation.png – แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



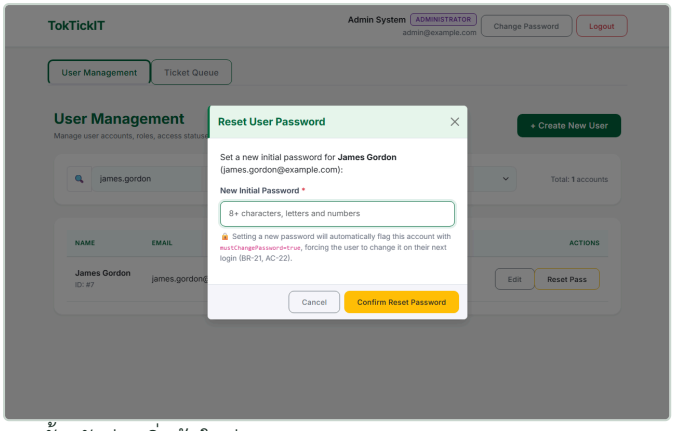
8.6 อีเมลผิดรูปแบบ / รหัสผ่านสั้นเกิน

`artifacts/lab-03/screenshots/user-management/04c-invalid-input-validation.png – แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



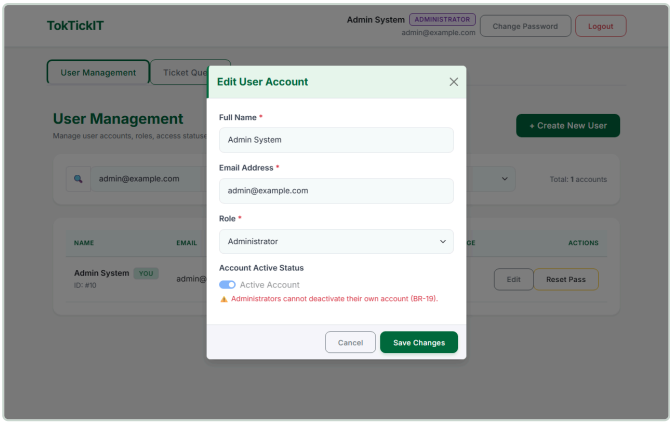
8.7 แก้ไขผู้ใช้และสวิตช์ Active

`artifacts/lab-03/screenshots/user-management/07-edit-user-modal.png`



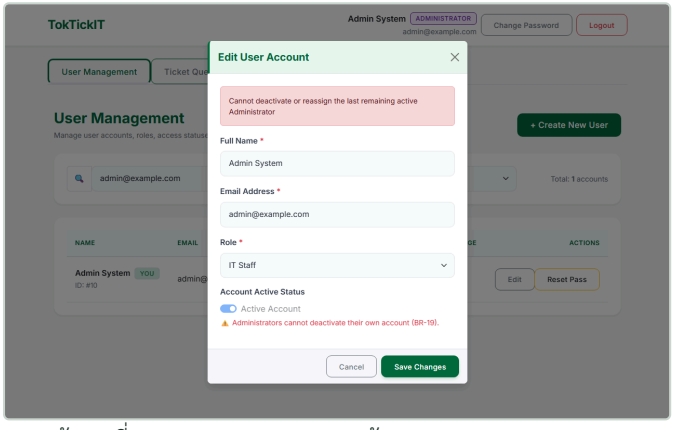
8.8 ตั้งรหัสผ่านเริ่มต้นใหม่

`artifacts/lab-03/screenshots/user-management/08-set-new-initial-password-modal.png`



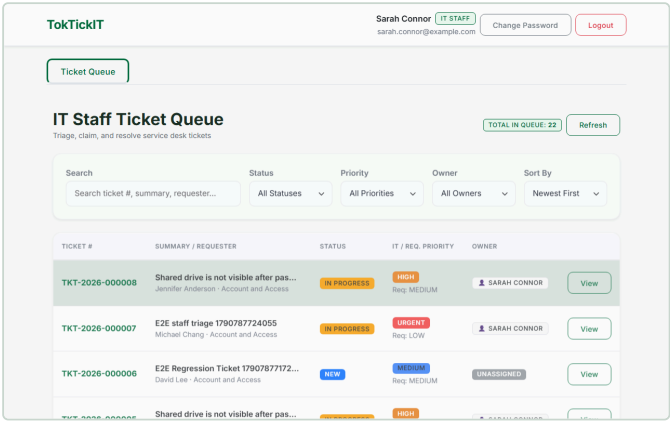
8.9 ห้ามปิดบัญชีตัวเอง (BR-19)

`artifacts/lab-03/screenshots/user-management/05-self-deactivation-guard.png`



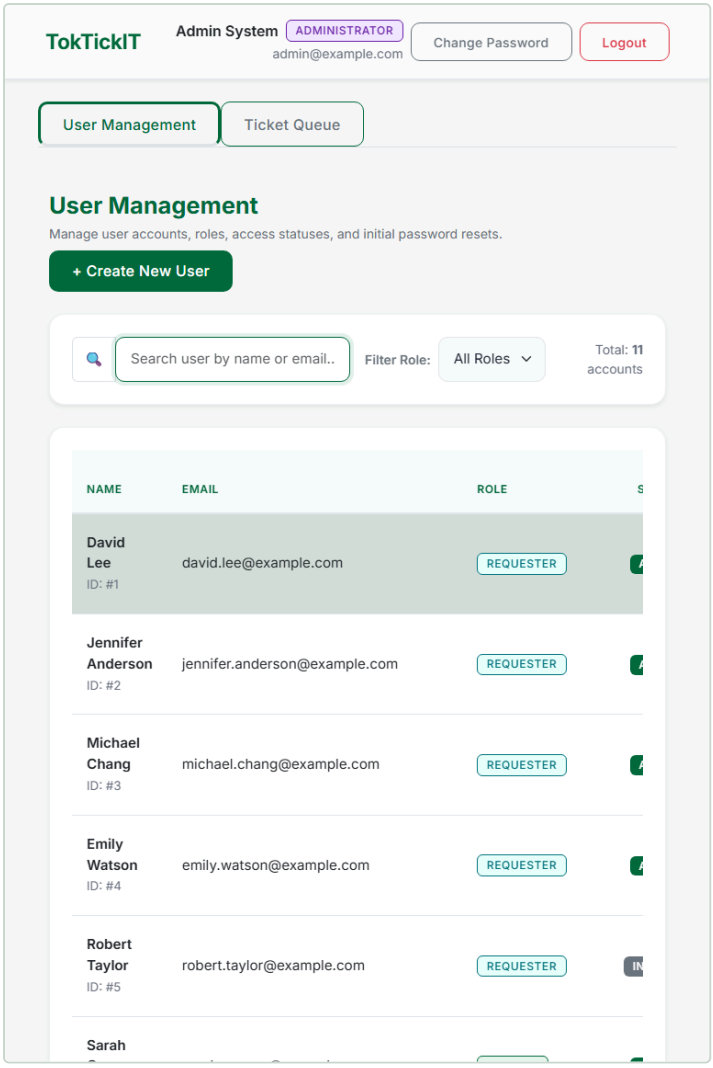
8.10 ห้ามเปลี่ยนบทบาท Admin คนสุดท้าย (BR-20)

`artifacts/lab-03/screenshots/user-management/06-last-active-admin-guard.png`



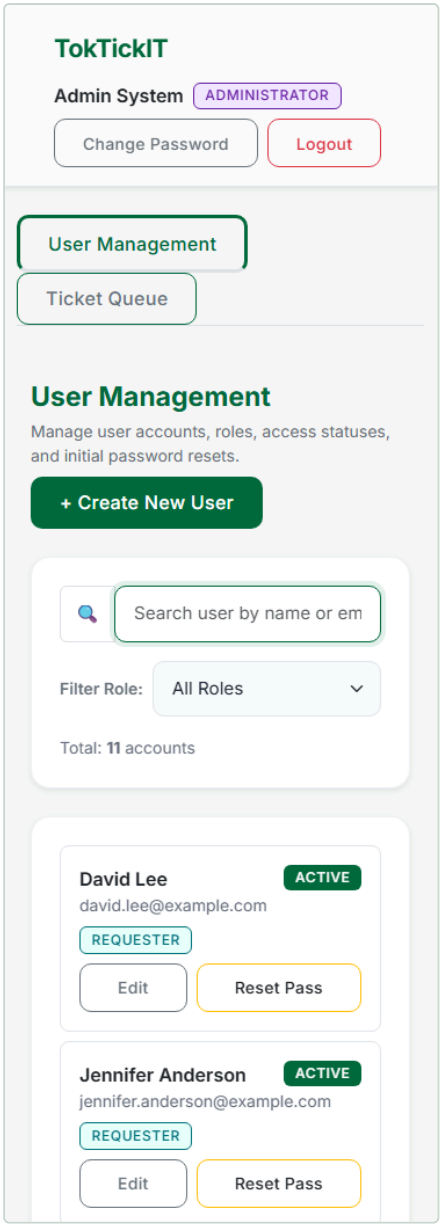
8.11 IT Staff ไม่มีเมนู User Management

`artifacts/lab-03/screenshots/user-management/11-non-admin-has-no-user-management.png – แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)`



8.12 Tablet 768px

`artifacts/lab-03/screenshots/user-management/09-user-management-tablet.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



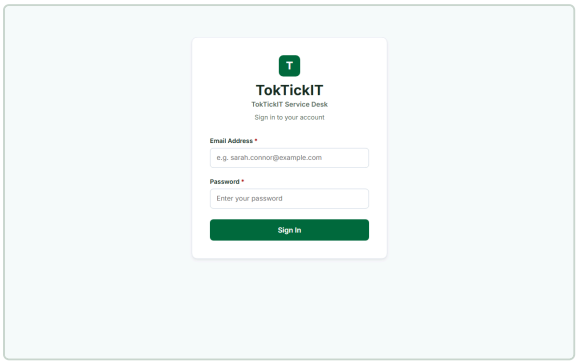
8.13 Mobile 375px: แสดงเป็นการ์ด

`artifacts/lab-03/screenshots/user-management/10-user-management-mobile.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)

Answer Part 9: Zen Green UI and Responsive Evidence

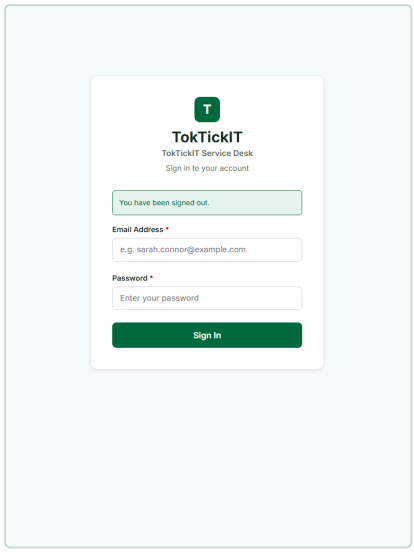
ลิงก์: docs/lab-03/ui-spec.md — ภาพทั้งหมดสร้างจาก UI ปัจจุบันด้วย `npm run screenshots` ที่ Desktop 1280px, Tablet 768px และ Mobile 375px (Visual Checklist อยู่ท้ายเอกสาร ui-spec ที่ render ด้านล่าง)

Login



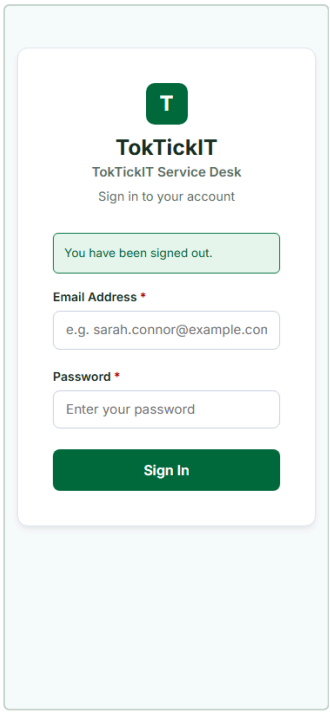
Desktop 1280px

`artifacts/lab-03/screenshots/authentication/01-login-desktop.png`



Tablet 768px

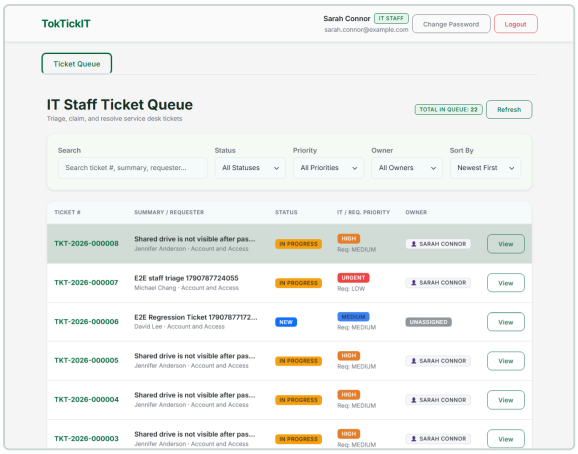
`artifacts/lab-03/screenshots/authentication/09-login-tablet.png`



Mobile 375px

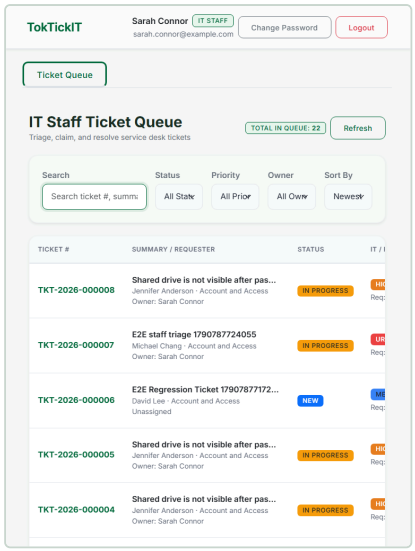
`artifacts/lab-03/screenshots/authentication/10-login-mobile.png`

IT Staff Ticket Queue



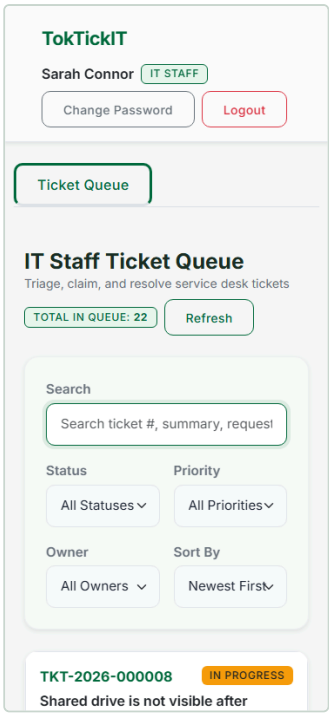
Desktop 1280px

`artifacts/lab-03/screenshots/staff-queue/01-queue-desktop.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



Tablet 768px

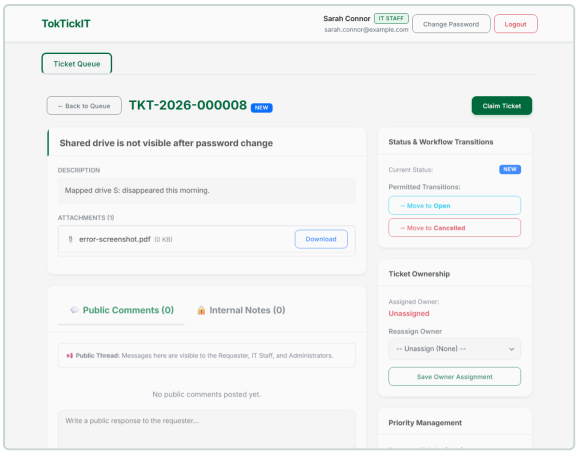
`artifacts/lab-03/screenshots/staff-queue/08-queue-tablet.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



Mobile 375px

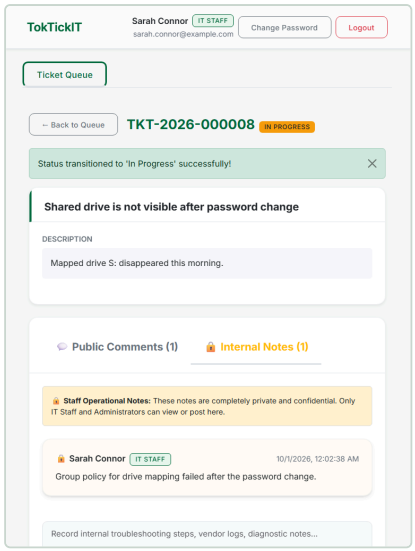
`artifacts/lab-03/screenshots/staff-queue/09-queue-mobile.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)

IT Staff Ticket Detail



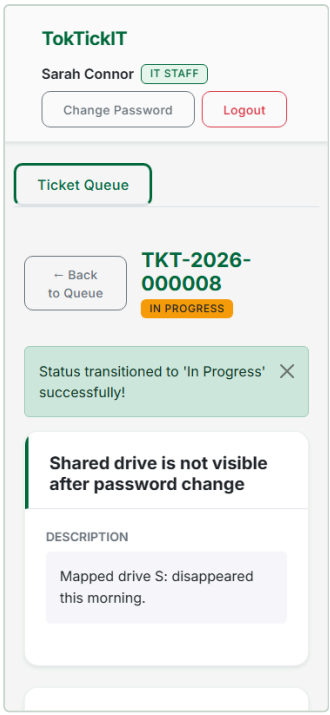
Desktop 1280px

`artifacts/lab-03/screenshots/staff-ticket-detail/01-ticket-detail-before-claim.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



Tablet 768px

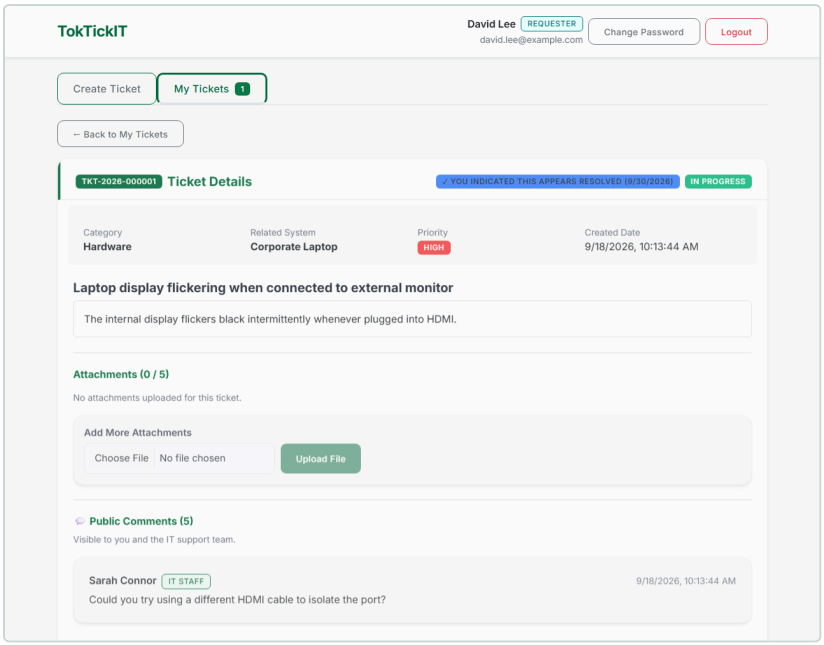
`artifacts/lab-03/screenshots/staff-ticket-detail/07-ticket-detail-tablet.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



Mobile 375px

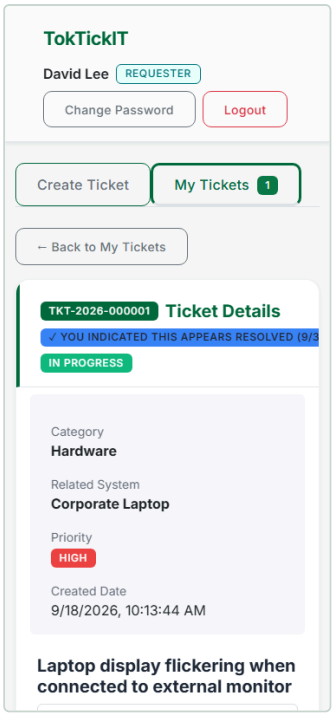
`artifacts/lab-03/screenshots/staff-ticket-detail/08-ticket-detail-mobile.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)

Requester Ticket Detail



Desktop 1280px

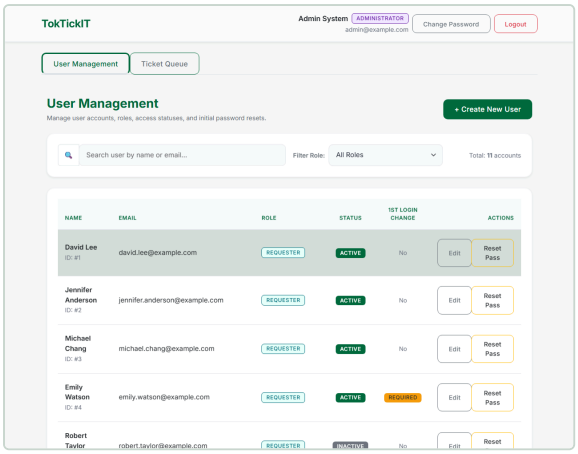
`artifacts/lab-03/screenshots/requester-ticket-detail/02-detail-with-public-comments.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



Mobile 375px

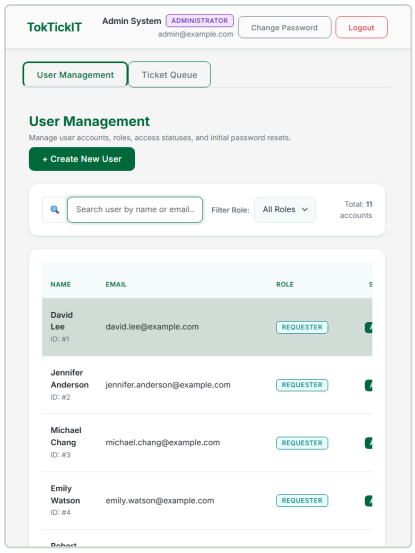
`artifacts/lab-03/screenshots/requester-ticket-detail/05-detail-mobile.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)

User Management



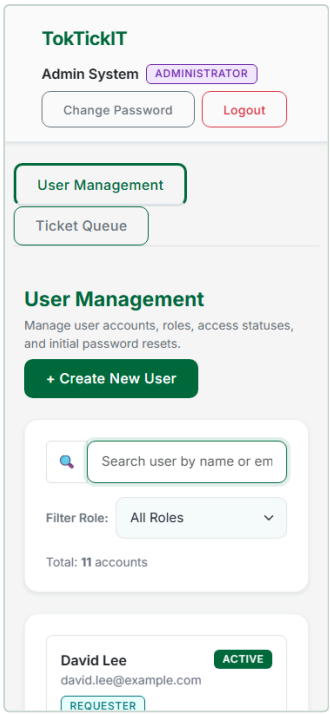
Desktop 1280px

`artifacts/lab-03/screenshots/user-management/01-user-list-desktop.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



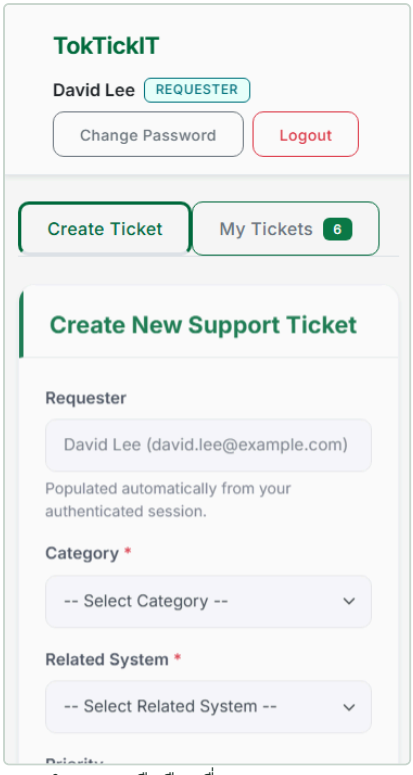
Tablet 768px

`artifacts/lab-03/screenshots/user-management/09-user-management-tablet.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



Mobile 375px

`artifacts/lab-03/screenshots/user-management/10-user-management-mobile.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)



แถบนำทางบนมือถือ: ชื่อ + Role Badge + Change Password + Logout

`artifacts/lab-03/screenshots/authentication/11-navbar-mobile.png` — แสดงส่วนบนของหน้า (ภาพเต็มอยู่ใน repository)

Rendered from docs/lab-03/ui-spec.md

Lab 3 UI Specification: Zen Green Theme & Operational Workflows

1. Color Tokens & Typography

Color System

- **Primary Green**: `#006B3C` (App header, primary action buttons, key badge accents)
- **Secondary Green**: `#0B7A46` (Active tabs, focus indicators, interactive hover states)
- **Pale Green**: `#EAF6EF` (Selected table rows, badge backgrounds, subtle callout cards)
- **Page Background**: `#F5F7F6` (Calm neutral off-white surface)
- **Card Surface**: `#FFFFFF` (Pure white cards with `#E2E8F0` border and soft elevation)
- **Primary Text**: `#1A2F25` (Dark pine charcoal for readability, high contrast)
- **Muted Text**: `#5C7164` (Secondary labels, timestamps, metadata)
- **Error / Destructive**: `#B30000` (Validation errors, danger alerts, deactivation warnings)
- **Warning / Attention**: `#D97706` (High priority badges, pending password change prompts)
- **Information**: `#2563EB` (Public notes accent, informational banners)

Role & Status Badges

- **Role Badges**:

  - `Requester`: Neutral light teal `#E6FFFA` with `#047481` text.
  - `IT Staff`: Pale green `#EAF6EF` with `#006B3C` text.
  - `Administrator`: Soft purple `#F3E8FF` with `#6B21A8` text.
- **Priority Badges**:
  - `LOW`: Light gray `#F1F5F9`, text `#475569`.
  - `MEDIUM`: Soft blue `#EFF6FF`, text `#1D4ED8`.
  - `HIGH`: Amber `#FEF3C7`, text `#B45309`.
  - `URGENT`: Red `#FEE2E2`, text `#B91C1C`.
- **Status Badges**:
  - `New`: Cyan `#E0F2FE`, text `#0369A1`.
  - `Open`: Blue `#DBEAFE`, text `#1D4ED8`.
  - `In Progress`: Amber `#FEF3C7`, text `#B45309`.
  - `Waiting for Requester`: Purple `#EDE9FE`, text `#6D28D9`.
  - `Resolved`: Green `#DCFCE7`, text `#15803D`.
  - `Closed`: Gray `#F3F4F6`, text `#4B5563`.
  - `Reopened`: Orange `#FFEDD5`, text `#C2410C`.
  - `Cancelled`: Red `#FEE2E2`, text `#991B1B`.

---

2. Component Conventions & States

Form Controls

- **Editable Input**: `#FFFFFF` background, `1px solid #CBD5E1` border, 8px border-radius, 40px minimum touch height.
- **Read-Only Field**: Soft warm ivory / light gray background `#F8FAFC`, non-editable cursor, distinct border.
- **Validation Errors**: Red text `#B30000` placed directly below input with a clear descriptive message.
- **Busy / Loading State**: Action buttons display a loading spinner and disable further clicks.

Dual Discussion Feed (Public Comments vs. Internal Notes)

- **Tab Navigation**: Clean pill or underline tab controls switching between "Public Comments" and "Internal Notes" (with a lock icon indicating internal restriction).
- **Public Comment Card**: White background, author name, role badge, timestamp, and standard border.
- **Internal Note Card**: Pale amber/yellow background `#FFFBEB` with `#FDE68A` border to clearly distinguish confidential notes from public messages.

---

3. Application Shell & Role-Based Navigation

- **Navbar Header**:
  - Brand Logo: "TokTickIT" in bold white against Primary Green (`#006B3C`).
  - Navigation Links (rendered based on authenticated role):

    - **Requester**: `My Tickets`, `Create Ticket`
    - **IT Staff**: `Ticket Queue`
    - **Administrator**: `User Management`, `Ticket Queue`
  - Right-aligned Profile Area: User full name and Role badge (visible on all viewports; email hidden on phones), `Change Password` button, and `Logout` button.
  - Development Requester Selector: **Completely removed** (no selector, no `X-Requester-Id`, no stored requester id).
  - Session feedback: after logout the login screen shows "You have been signed out."; if the server rejects the session (expired, revoked, deactivated) it shows "Your session has ended. Please sign in again."

---

4. Screen Specifications

4.1 Login Screen

- Centered card layout on `#F5F7F6` background.
- Form inputs: Email address, Password.
- "Sign In" button with busy indicator.
- Error alerts: Invalid credentials, inactive account warning banner.

4.2 Mandatory Change Password Screen

- Full-screen dialog that replaces the application if `mustChangePassword === true`; only a small "Sign out" button remains.
- Explanatory prompt notifying that the initial password must be updated.
- Inputs: Current Password, New Password, Confirm New Password.
- Password rule hint under the field: 8–72 characters, at least one letter and one number; confirmation must match.
- Normal application navigation is not rendered and no application data is loaded until completed.
- The same dialog opens from the `Change Password` button for a voluntary change, with a `Cancel` button and a success message afterwards.

4.3 IT Staff Ticket Queue Screen

- **Header & Stats Bar**: Shows active queue count.
- **Search & Filter Bar**:
  - Keyword search input (ticket number, summary, requester name).
  - Status filter dropdown (`All` plus all 8 statuses, including `Reopened` and `Cancelled`).
  - Priority filter dropdown (`All`, `LOW`, `MEDIUM`, `HIGH`, `URGENT`).
  - Owner filter dropdown (`All`, `Unassigned`, `Assigned to Me`, `Specific Staff`).
  - Sort dropdown (Newest / Oldest, Ticket # ascending / descending, Priority).
- **Table (≥ 768px)**:

- Columns: Ticket #, Summary with Requester and Category underneath, Status, IT Priority badge with "Req:" Requested Priority underneath, Owner (≥ 992px; otherwise shown under the summary), Created (≥ 1400px), and a `View` button.
- Row click or `View` opens IT Staff Ticket Detail.

- **Card list (< 768px)**: one card per ticket with number, status badge, summary, requester and category, priorities, owner, and a full-width `View` button.
- **States**: Loading spinner, empty queue message, no-results message with a Clear Filters button, safe error message.
- **Pagination**: Previous / Next buttons, numbered pages, and "Showing page X of Y (N tickets)"; 10 tickets per page.

4.4 IT Staff Ticket Detail Screen

- **Top Navigation Bar**: "Back to Queue" button, Ticket Number heading, and current Status badge.
- **Action Control Bar**:
  - Ownership: "Claim Ticket" button, plus an owner dropdown (active IT Staff and Administrators, or Unassign) with "Save Owner Assignment".
  - IT Priority: Select dropdown with "Save IT Priority"; Requested Priority is shown read-only and labelled "Immutable".
  - Status Workflow: one "Move to ..." button per permitted next status; terminal statuses show an explanation instead of buttons.
- **Main Section (2-Column Layout on Desktop)**:
  - Left Column: Issue details (Summary, Category, Related System, Full Description, Attachments download list).
  - Right Column: Requester info card, Resolution indication notice (if flagged by requester), and Activity / Discussion feed (Public Comments and Internal Notes tabs).

4.5 Requester Ticket Detail Screen (Lab 2 view, extended)

- Header: ticket number, status badge, and `My Problem Appears Resolved` button (hidden once indicated or when Resolved/Closed/Cancelled; replaced by an "indicated" badge with the date).
- Read-only metadata row, description, and attachments (download, remove with required reason, upload more).
- **Public Comments** thread: author name, role badge, timestamp, plain-text content, empty state, loading and retry-on-error states, textarea with 2,000-character counter, and "Comment posted." confirmation. Hidden form on Closed/Cancelled tickets. Internal Notes are never shown.
- Inline success / error alerts instead of browser pop-ups.
- A ticket that is missing or belongs to another Requester shows "Ticket Unavailable" without revealing whether it exists.

4.6 Administrator User Management Screen

- **Header**: Title "User Management", total active users counter, and "+ Create User" primary action button.
- **Filter Bar**: Search input (Name or Email), Role filter (`All`, `Requester`, `IT Staff`, `Administrator`).
- **User Table (≥ 768px)**:
  - Columns: Name, Email, Role (shared role badge), Status (`Active` / `Inactive` badge), 1st Login Change, Actions.
  - Actions: "Edit" button and "Reset Pass" (set new initial password) button.
- **Card list (< 768px)**: one card per user with name, status, email, role badge, password-change flag, and Edit / Reset Pass buttons.
- **Create User Modal**: Name, Email, Role dropdown (single role), Initial Password input (same password rules as Change Password; invalid email and duplicate email shown inside the modal).
- **Edit User Modal**: Name, Email, Role, and Active/Inactive toggle switch (deactivation alert).
- **Safety Safeguards**:
  - Active switch disabled (with a BR-19 warning) when editing the current Administrator's own account.
  - Server error shown inside the modal when trying to deactivate or demote the last active Administrator (BR-20).

---

5. Responsive Layout Breakdown

Viewport	Target Width	Layout Strategy
Desktop	`>= 992px`	Multi-column layouts; queue and user tables with all key columns visible without scrolling at 1280px; side-by-side Ticket Detail panels.
Tablet	`768px - 991 px`	Condensed tables (secondary columns folded under the summary); filter bar wraps to two rows; Ticket Detail stacks.
Mobile	`< 768px`	Single-column stacking; queue and user list rendered as cards instead of tables; header keeps name and role badge visible; full-width modal dialogs.

Evidence: `artifacts/lab-03/screenshots/` (desktop 1280px, tablet 768px, mobile 375px), regenerated with `npm run screenshots`.

Visual Checklist (for Lab 3 Part 9 Evidence)

- ☑ **Design consistency**: Zen Green colour tokens applied across all screens; new screens match the Lab 2 cards, buttons, and forms.
- ☑ **Role navigation**: each role sees only its permitted destinations (`authentication/08-navigation-*.png`, `user-management/11-non-admin-has-no-user-management.png`).
- ☑ **Badges**: one shared role badge style everywhere; status and priority badges use distinct colours with readable text; the queue shows both IT and Requested Priority.
- ☑ **Editable vs read-only**: editable inputs have white backgrounds and borders; read-only values (e.g. Requested Priority "Immutable", ticket metadata) are plain text or tinted panels.
- ☑ **Validation placement**: required fields marked `*`; errors appear directly under the field or at the top of the dialog (`authentication/04b-*`, `user-management/04b-*`, `04c-*`, `06-*`).

- ☑ **Focus**: the active input shows a green focus ring; all actions are buttons reachable by keyboard; dialogs use `aria-modal` with a title.
- ☑ **Clipping**: no truncated columns or cut-off buttons at 1280px, 768px, or 375px.
- ☑ **Overlap**: header, tabs, and dialogs do not overlap content; full-page screenshots are captured from the top of the page.
- ☑ **Horizontal overflow**: no page-level horizontal scrolling on any viewport; wide lists switch to cards under 768px.
- ☑ **Discussion threads**: Public Comments (grey cards) and Internal Notes (amber cards with a lock icon) are clearly distinguished; Requesters never see Internal Notes.
- ☑ **Modals**: create/edit user, set initial password, change password, and attachment removal dialogs fit within mobile viewports.